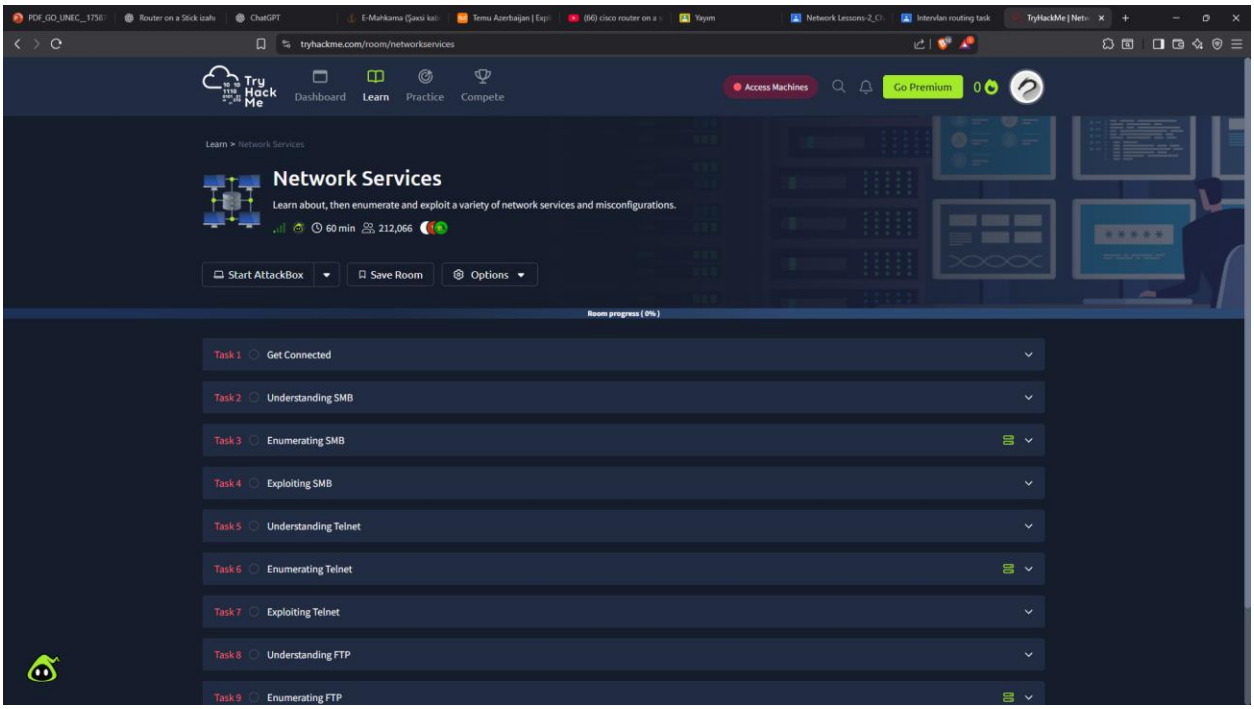
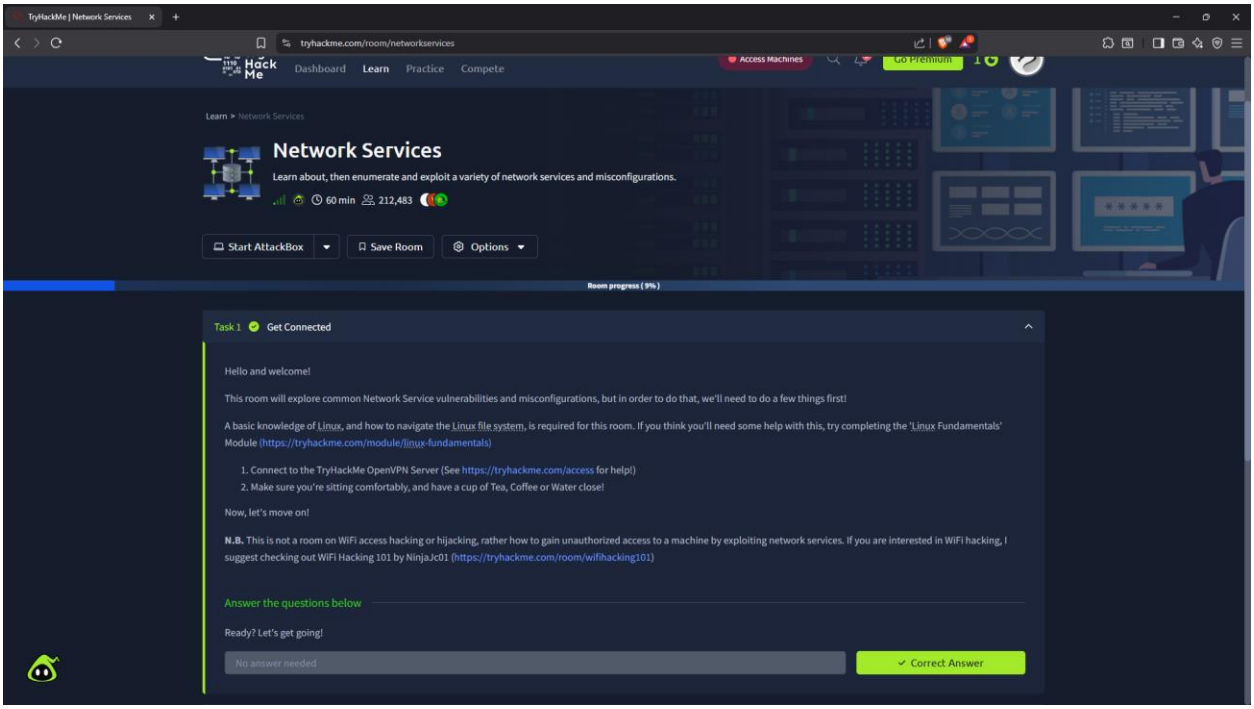
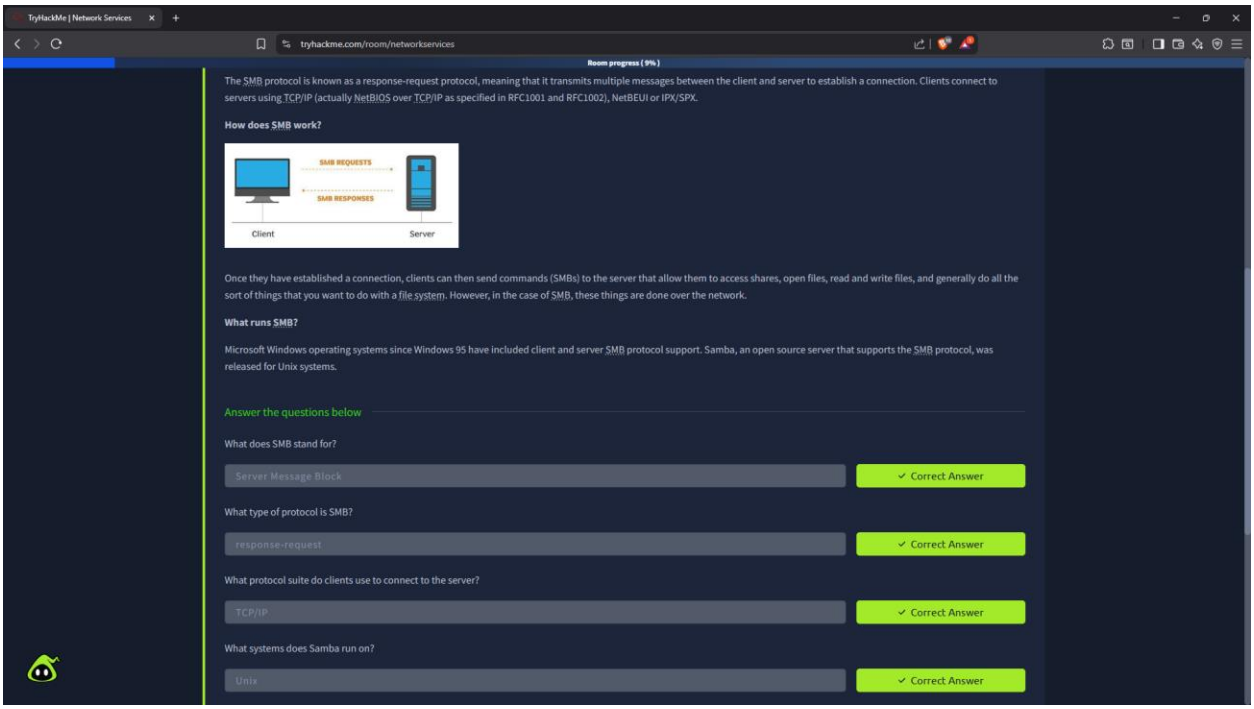


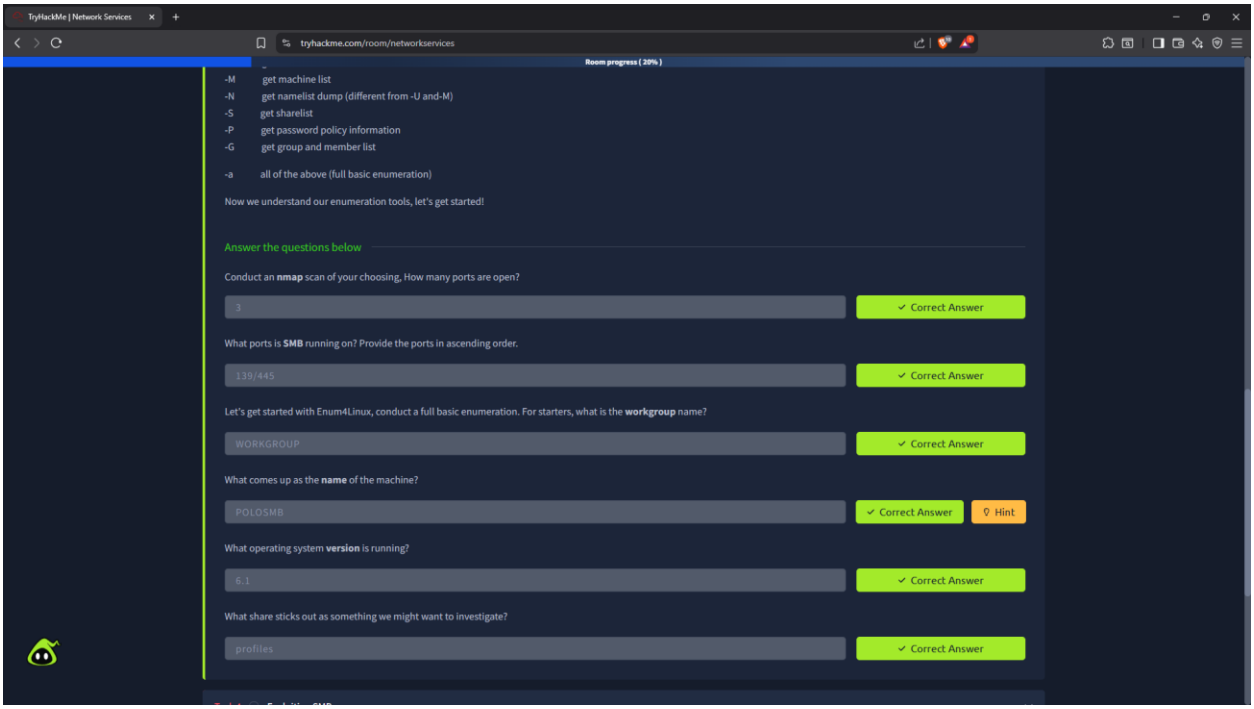
İlk öncə taskı sıfırladım



Bu ilk hissədi

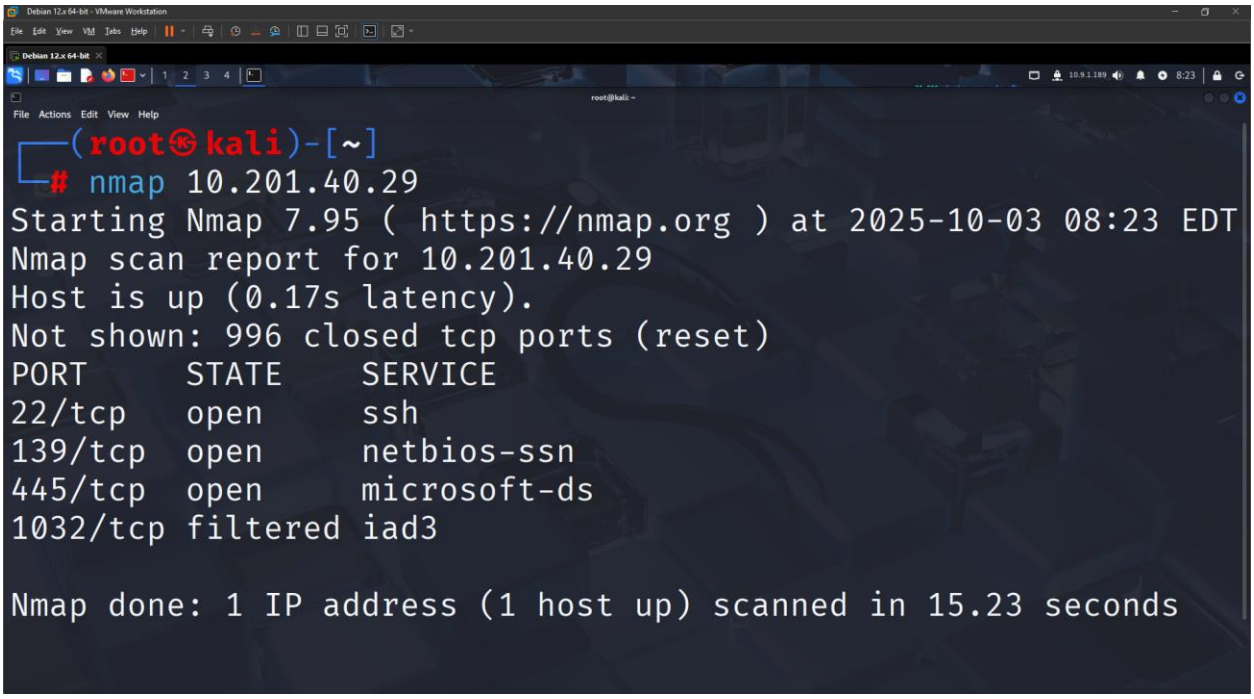


SMB haqqında məlumat oxudum və sualları cavablandırdım

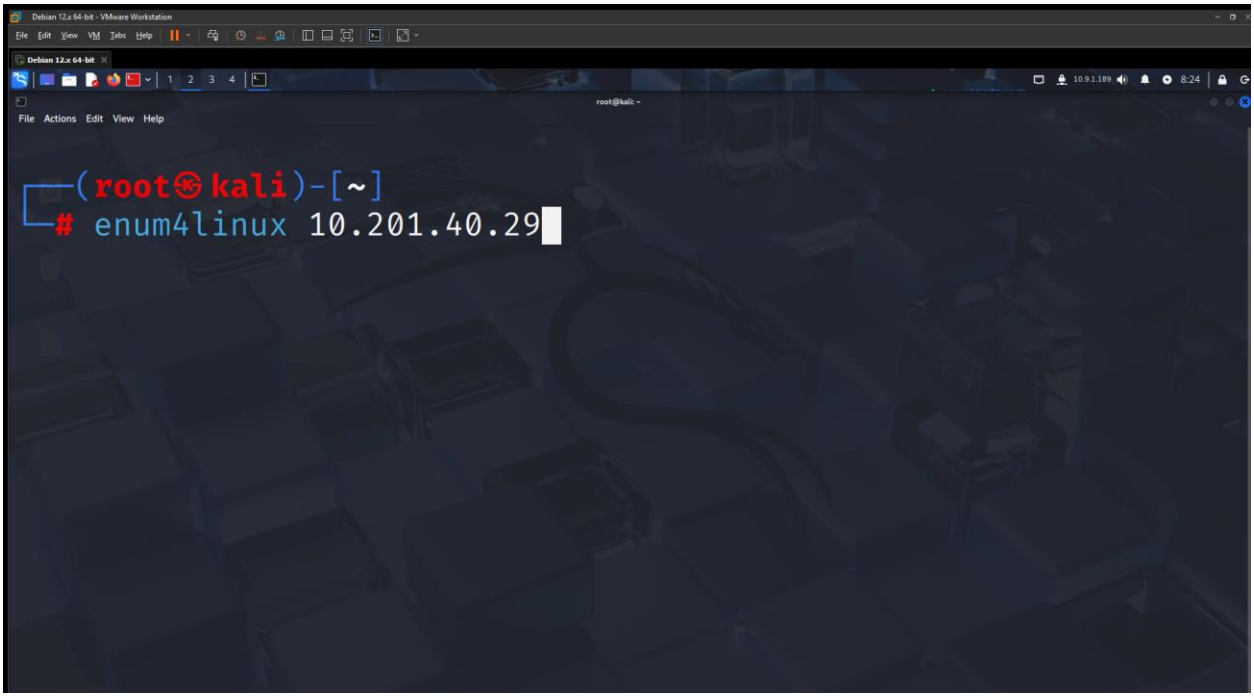


Burdakı sualların cavablarını necə tapdıgimi aşagida gğstərəcəm Bu hissə SMB Enumuration adlanır

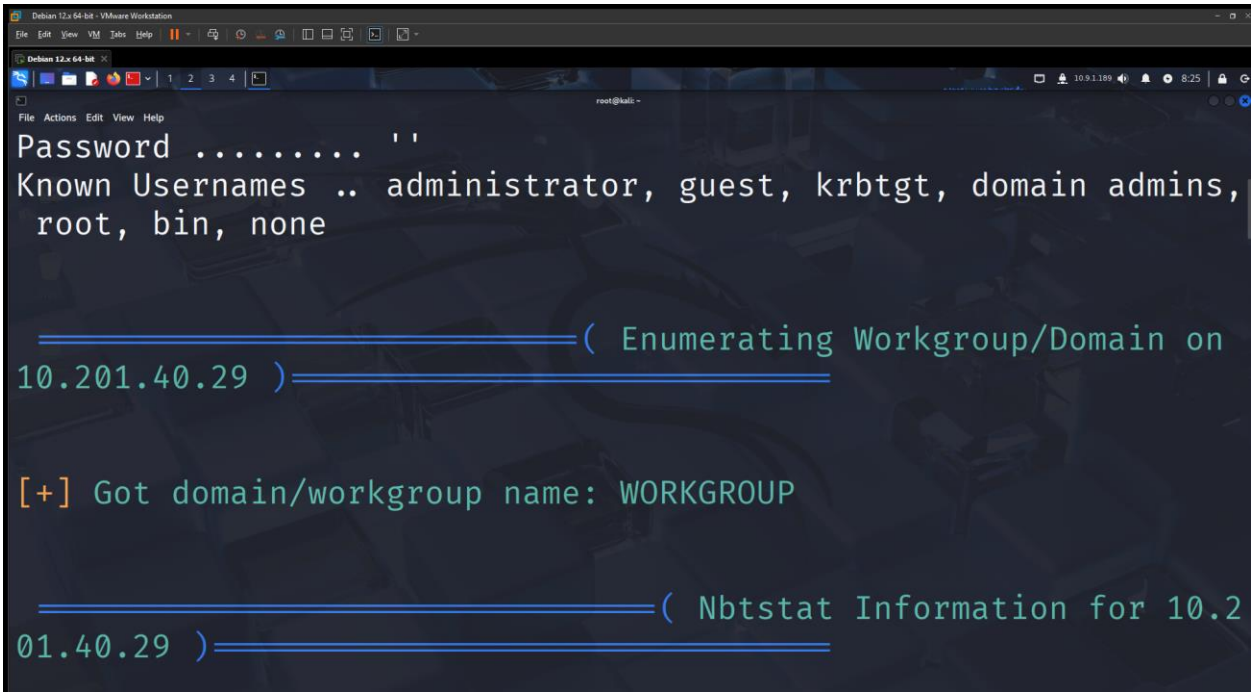




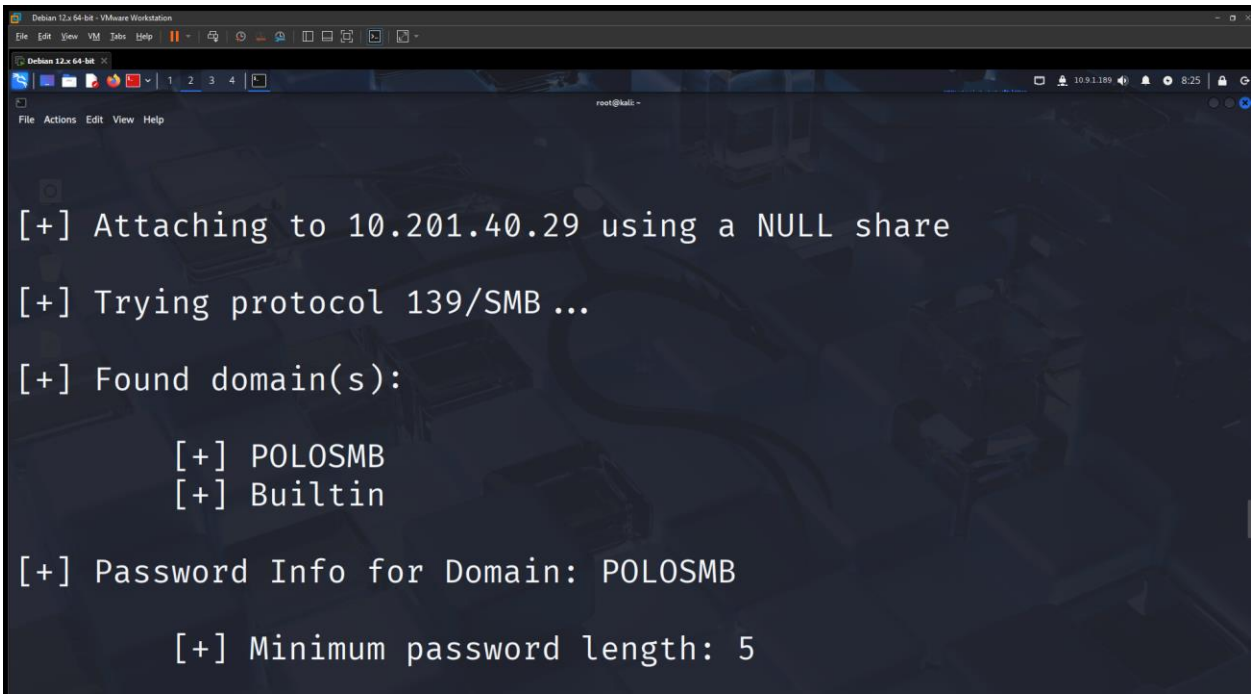
Burda bızdən neçə ədəd portun açiğ olğu soruşulur. Bunun nmap istifadə edirik. Sonra SMB-nın hansı portlar üzərində şalışdığı soruşulur. 139\445



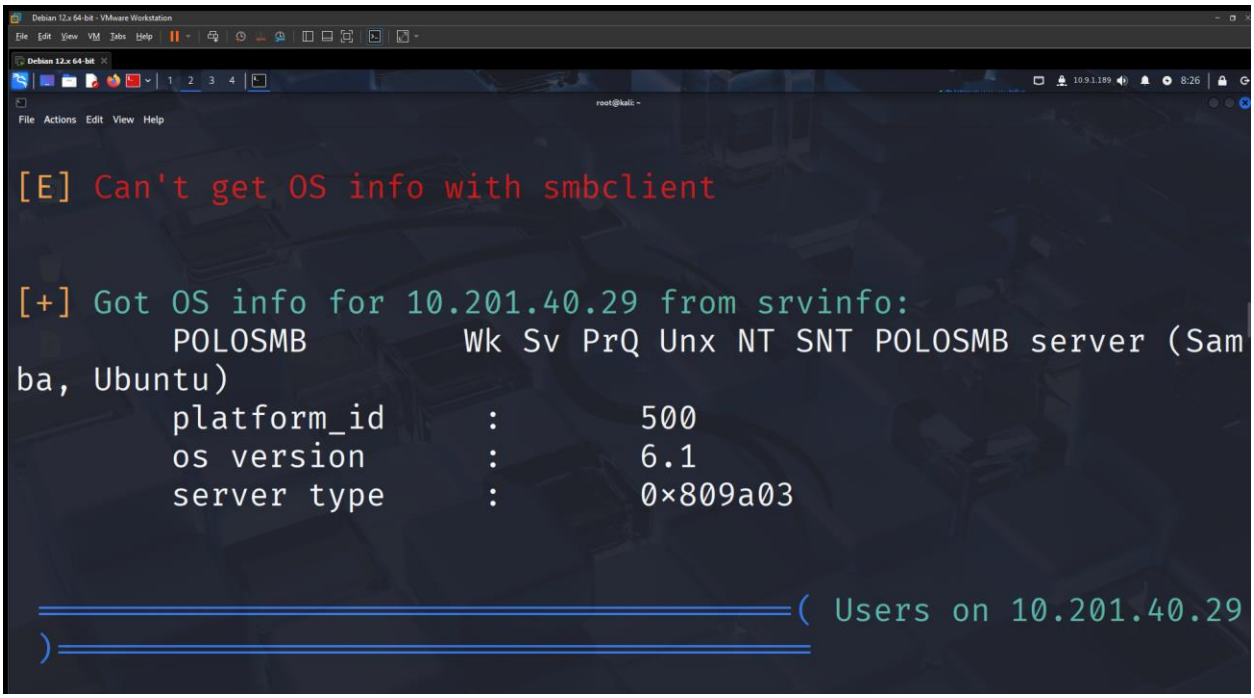
Sonra bizdən VorkGroup adı soruşduğundan enum4linux alətindən istifadə edirik.



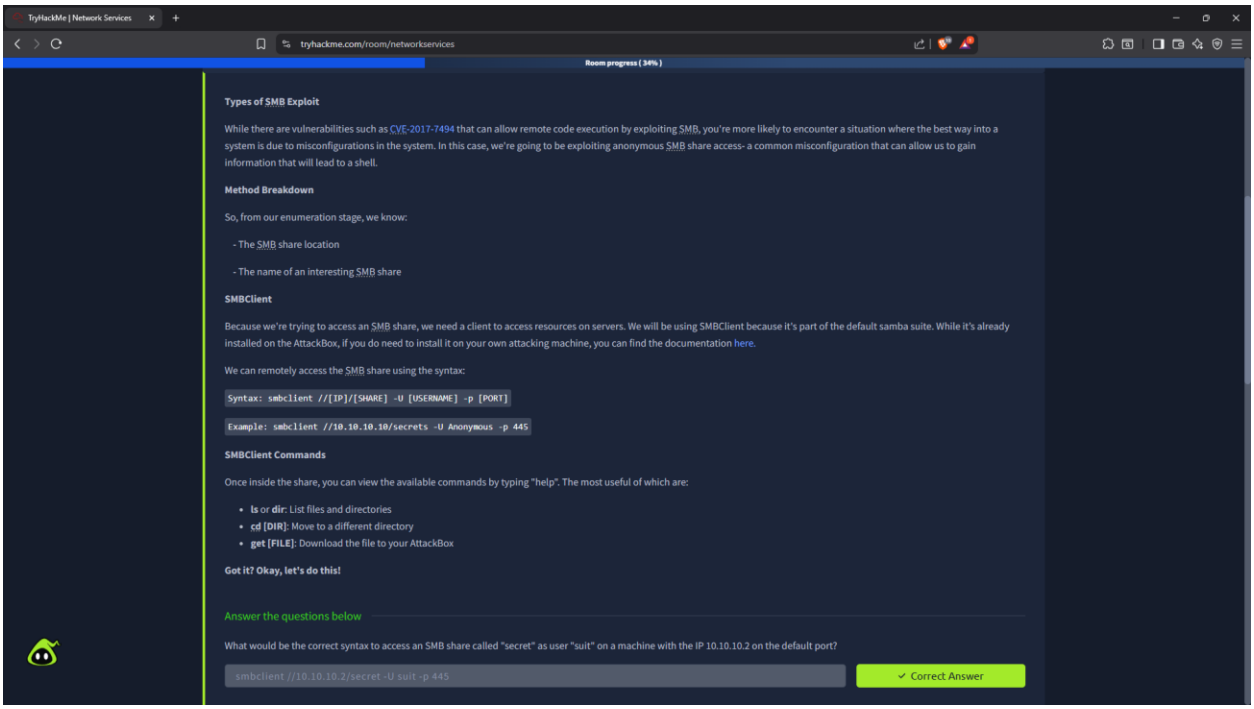
Vorkgroup adı

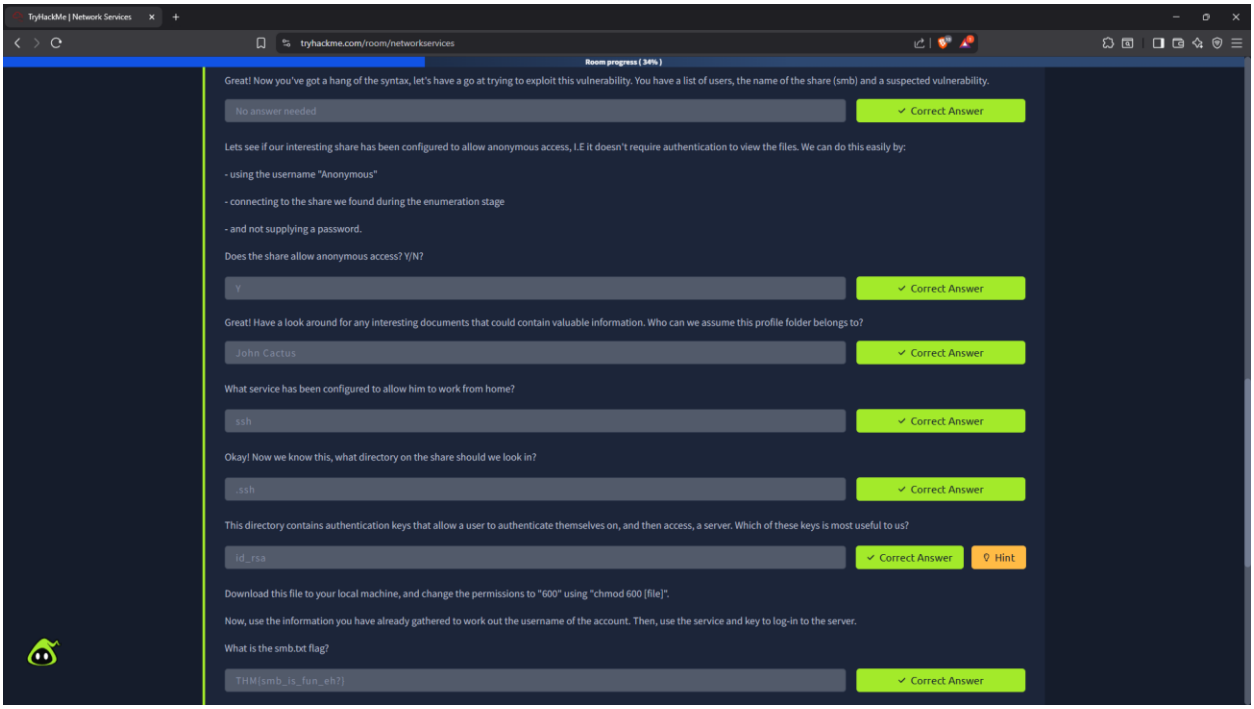


Maşının adı soruşulur.

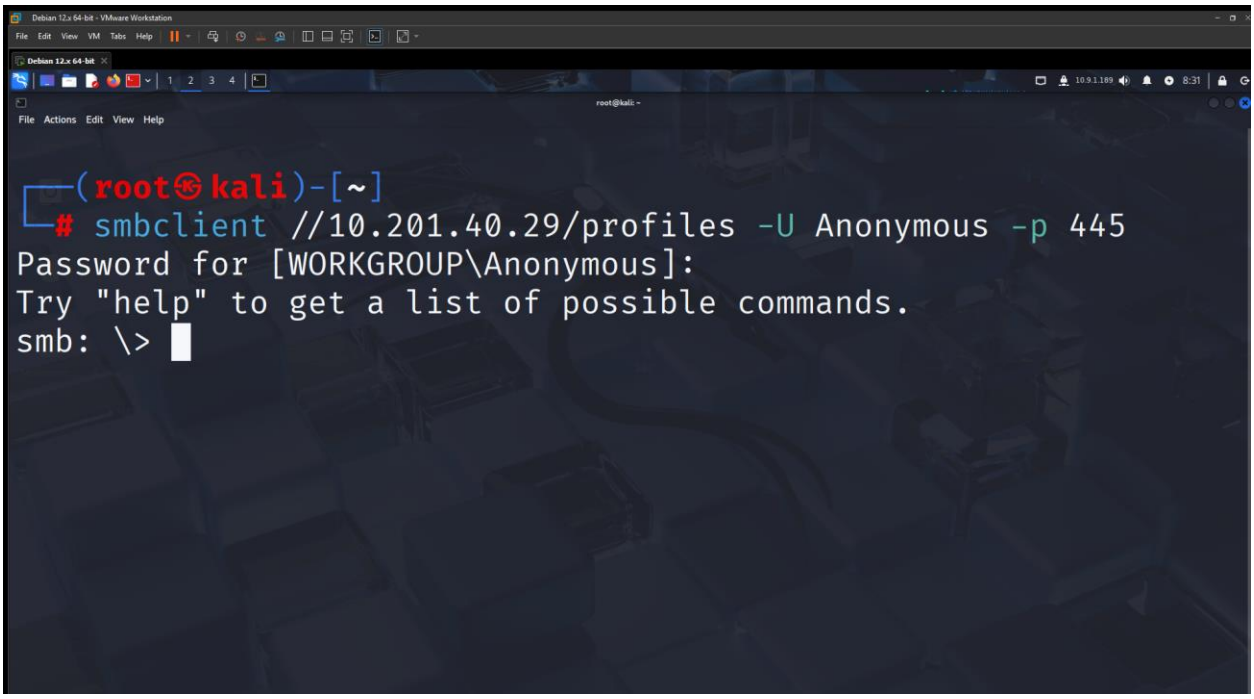


Maşının versiyası.

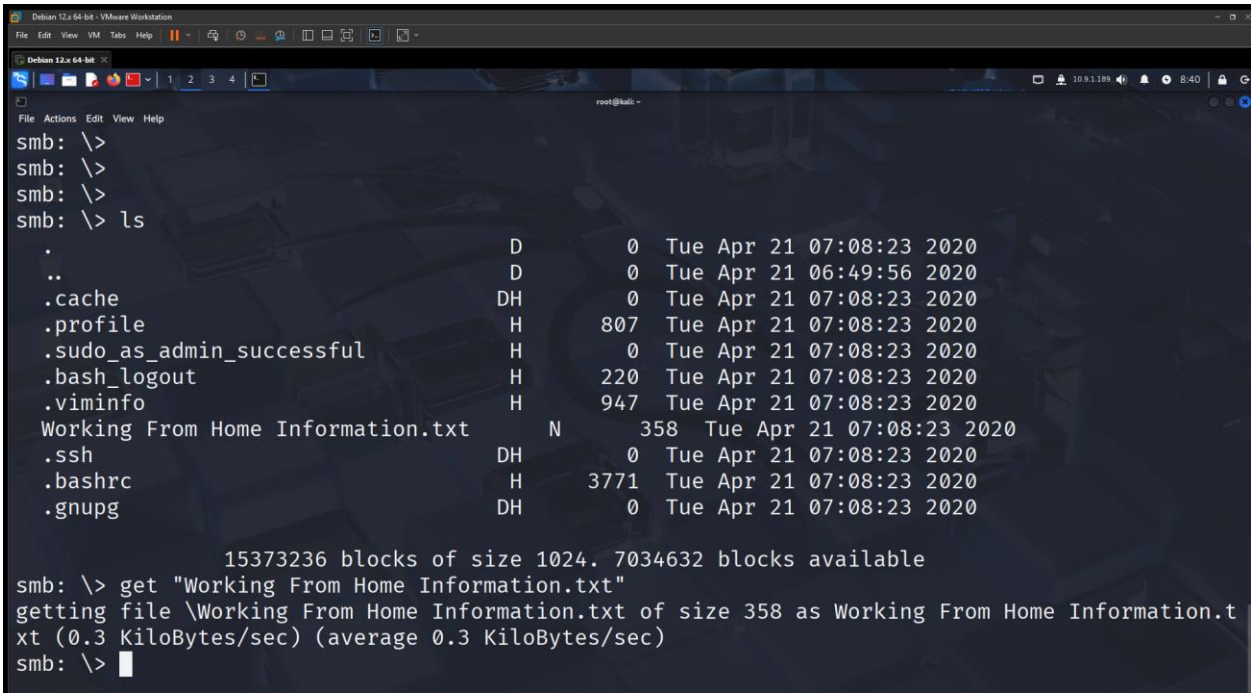

TryHackMe | Network Services
tryhackme.com/room/networkservices
Room progress (34%)
Types of SMB Exploit
While there are vulnerabilities such as CVE-2017-7494 that can allow remote code execution by exploiting SMB, you're more likely to encounter a situation where the best way into a system is due to misconfigurations in the system. In this case, we're going to be exploiting anonymous SMB share access- a common misconfiguration that can allow us to gain information that will lead to a shell.
Method Breakdown
So, from our enumeration stage, we know:
- The SMB share location
- The name of an interesting SMB share
SMBClient
Because we're trying to access an SMB share, we need a client to access resources on servers. We will be using SMBClient because it's part of the default samba suite. While it's already installed on the AttackBox, if you do need to install it on your own attacking machine, you can find the documentation here.
We can remotely access the SMB share using the syntax:
Syntax: smbclient //[IP]/[SHARE] -U [USERNAME] -p [PORT]
Example: smbclient //10.10.10.10/secrets -U Anonymous -p 445
SMBClient Commands
Once inside the share, you can view the available commands by typing "help". The most useful of which are:
ls or dir: List files and directories
cd [DIR]: Move to a different directory
get [FILE]: Download the file to your AttackBox
Got it? Okay, let's do this!
Answer the questions below
What would be the correct syntax to access an SMB share called "secret" as user "suit" on a machine with the IP 10.10.10.2 on the default port?
smbclient //10.10.10.2/secret -U suit -p 445
Correct Answer


TryHackMe | Network Services
tryhackme.com/room/networkservices
Room progress (34%)
Great! Now you've got a hang of the syntax, let's have a go at trying to exploit this vulnerability. You have a list of users, the name of the share (smb) and a suspected vulnerability.
No answer needed
Correct Answer
Lets see if our interesting share has been configured to allow anonymous access, I.E it doesn't require authentication to view the files. We can do this easily by:
- using the username "Anonymous"
- connecting to the share we found during the enumeration stage
- and not supplying a password.
Does the share allow anonymous access? Y/N?
Y
Correct Answer
Great! Have a look around for any interesting documents that could contain valuable information. Who can we assume this profile folder belongs to?
John Cactus
Correct Answer
What service has been configured to allow him to work from home?
ssh
Correct Answer
Okay! Now we know this, what directory on the share should we look in?
.ssh
Correct Answer
This directory contains authentication keys that allow a user to authenticate themselves on, and then access, a server. Which of these keys is most useful to us?
id_rsa
Correct Answer
Hint
Download this file to your local machine, and change the permissions to "600" using "chmod 600 [file]".
Now, use the information you have already gathered to work out the username of the account. Then, use the service and key to log-in to the server.
What is the smb.txt flag?
THM{smb_is_fun_eh?}
Correct Answer

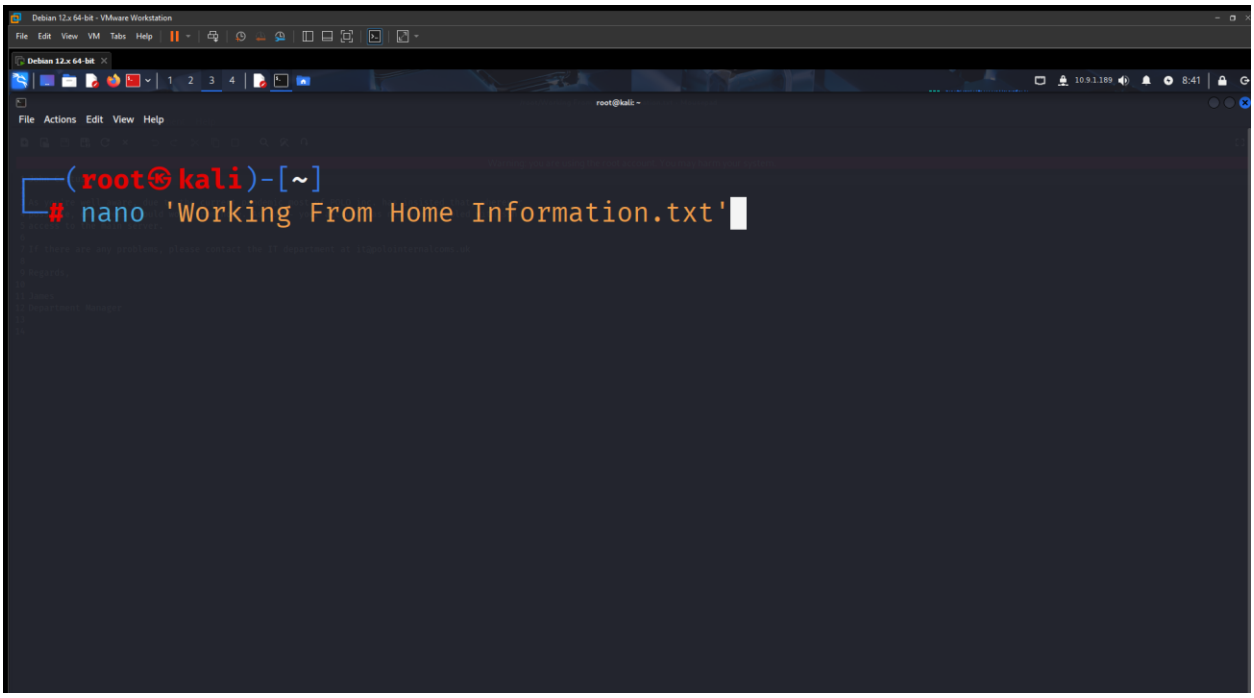
Burda ilk növbədə smbclient toolundan istifadə edirik.



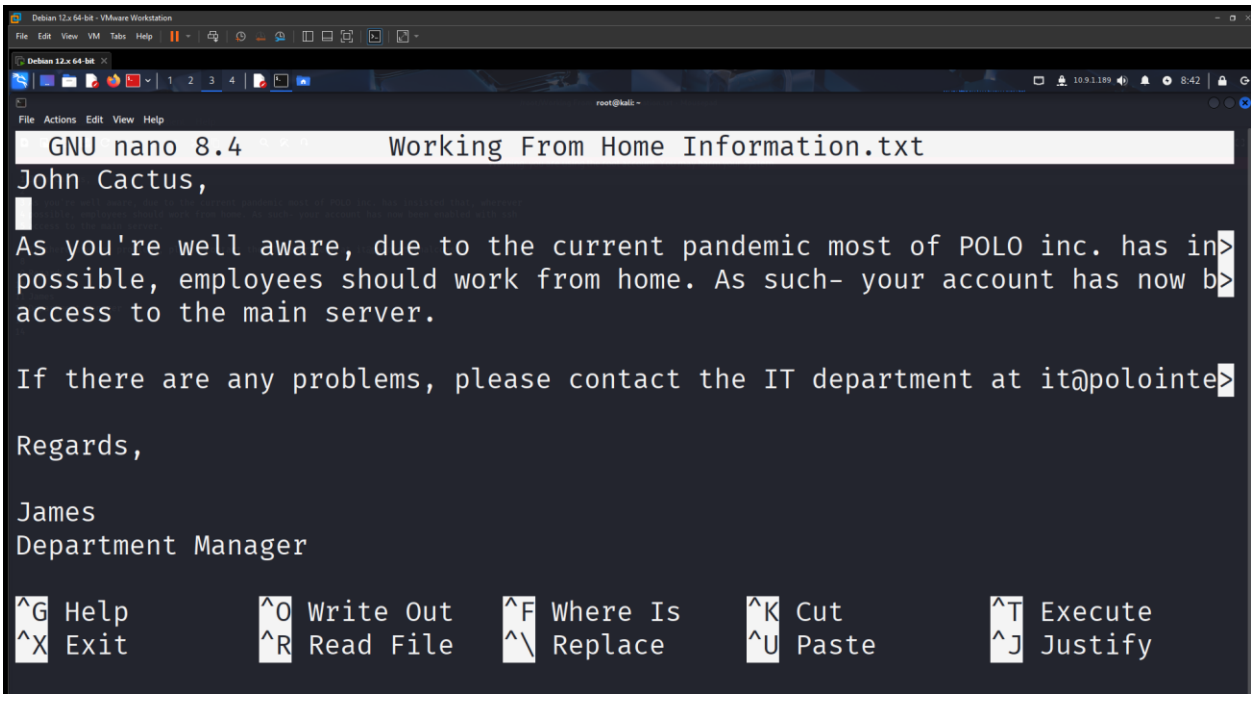
Anonim olaraq qoşuluruq.



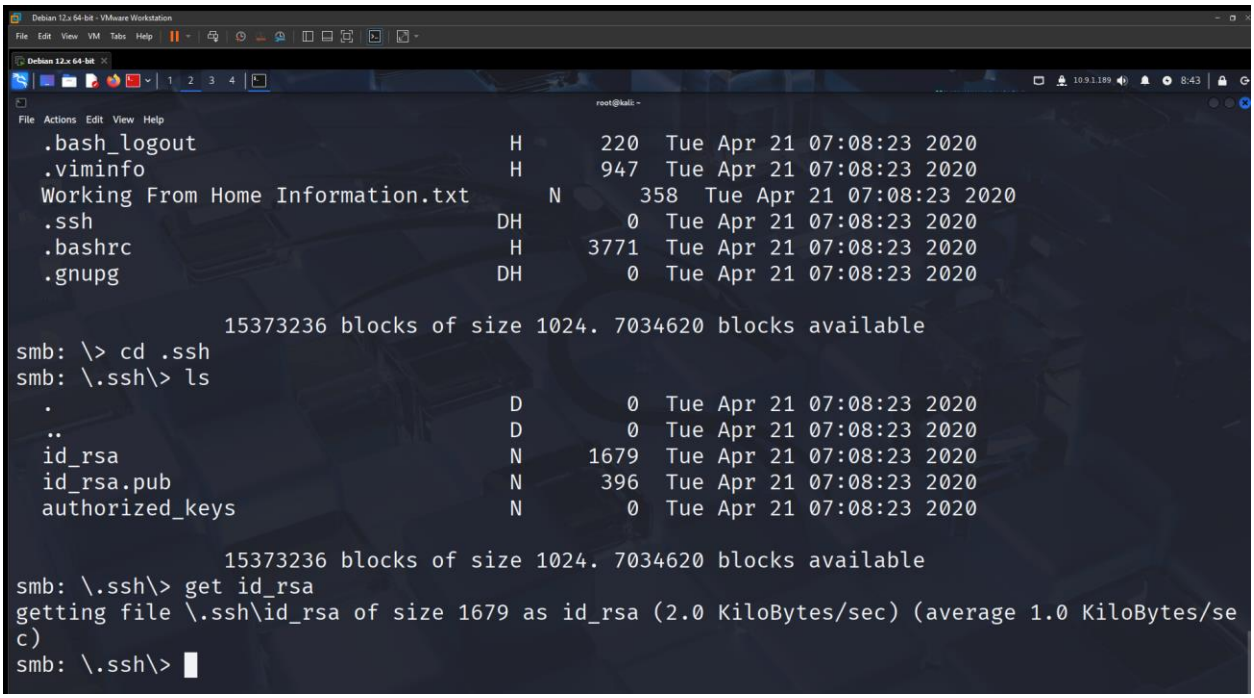
İnformation.txt faylını pc mizə kopyalayırıq.



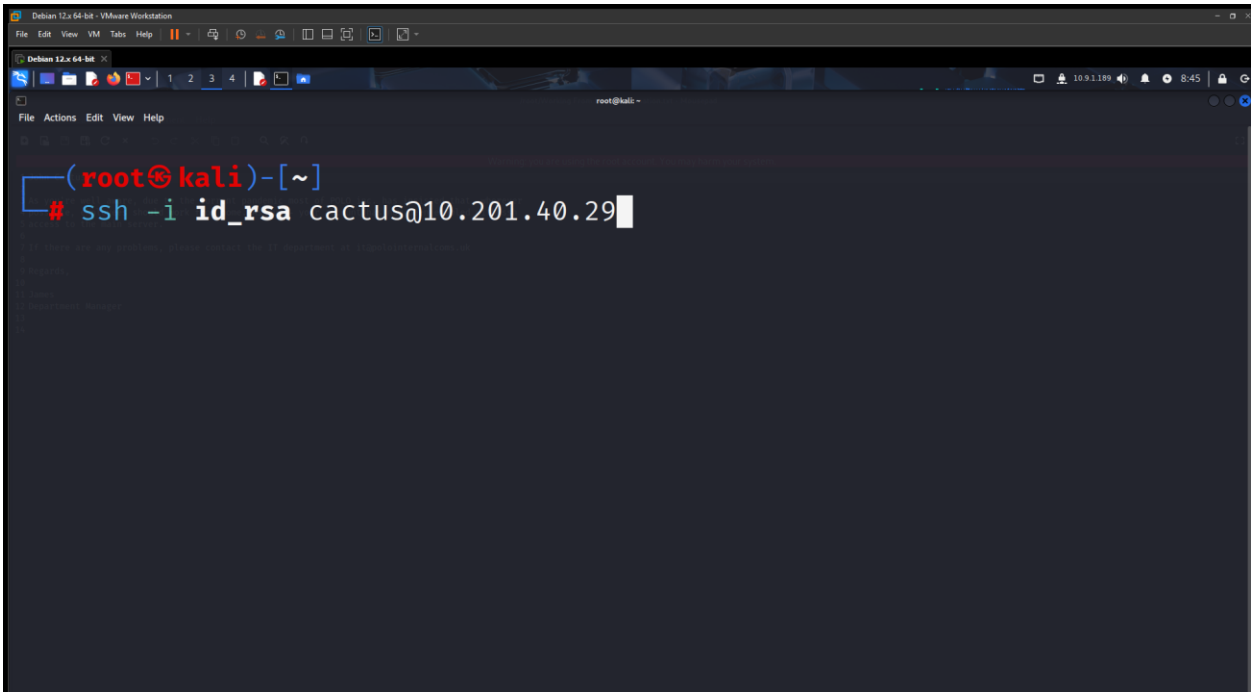
Faylı oxuyuruq.



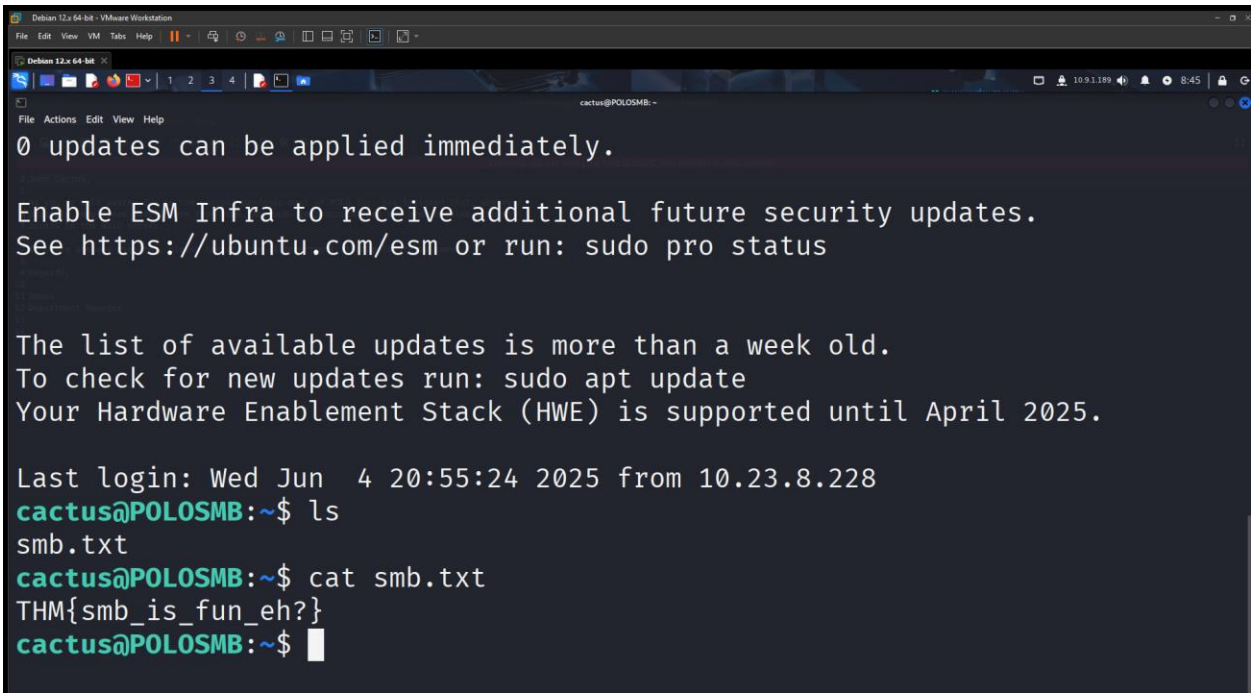
Userin adını Tapırıq deməli John Cactus. Və ssh təlimatların oxuyuruq.



SSH üçün id_rsa keyini pc mizə atırıq.

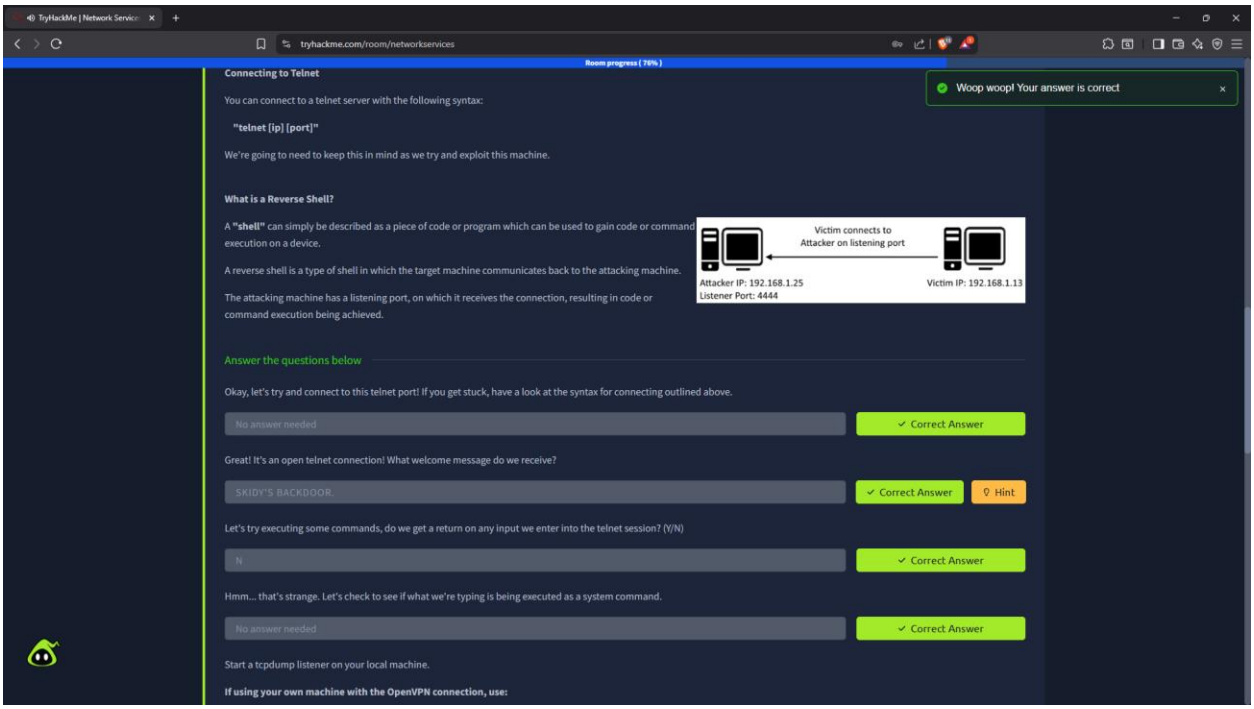


Və SSH ilə qoşuluruq.

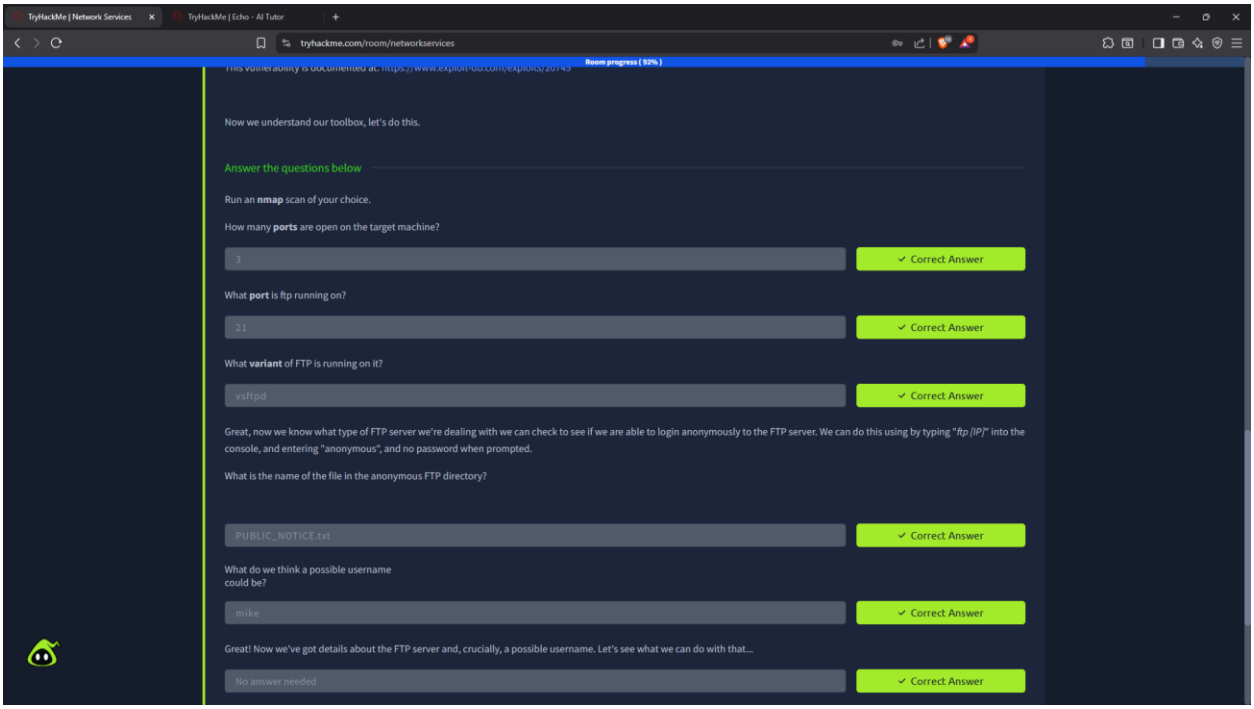


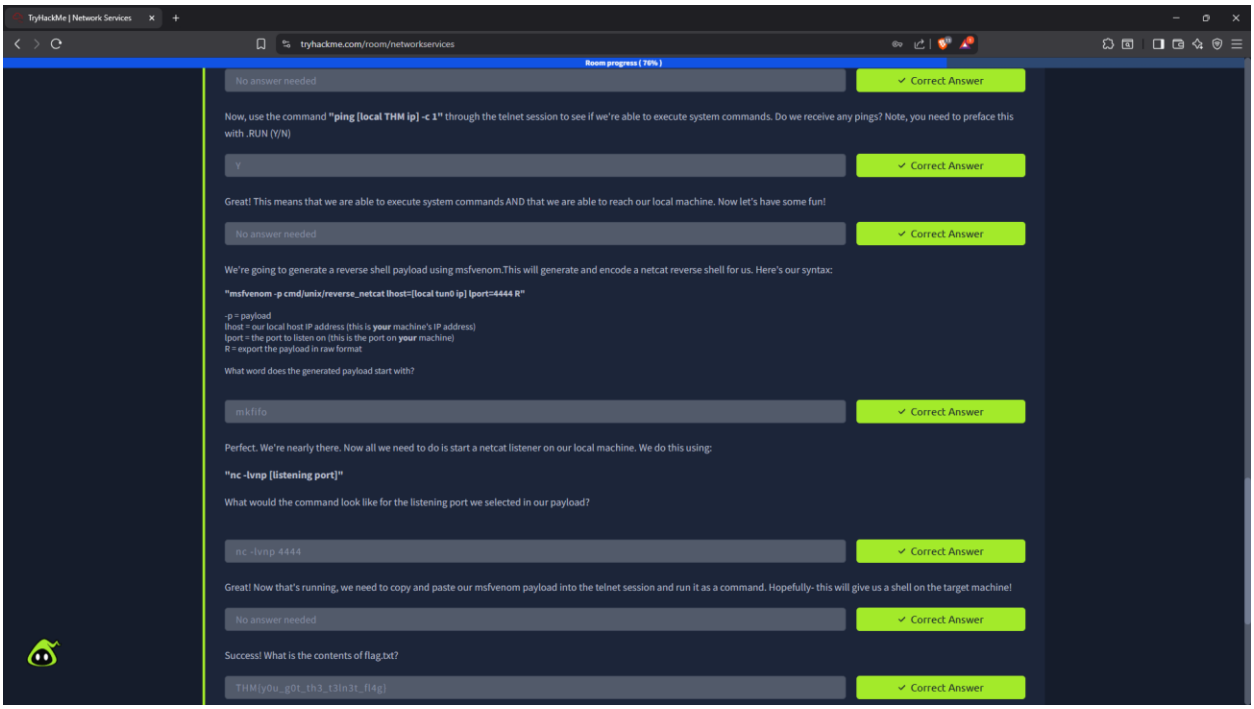
Qoşulduqdan sonra flagi oxuyuruq.

TELNET

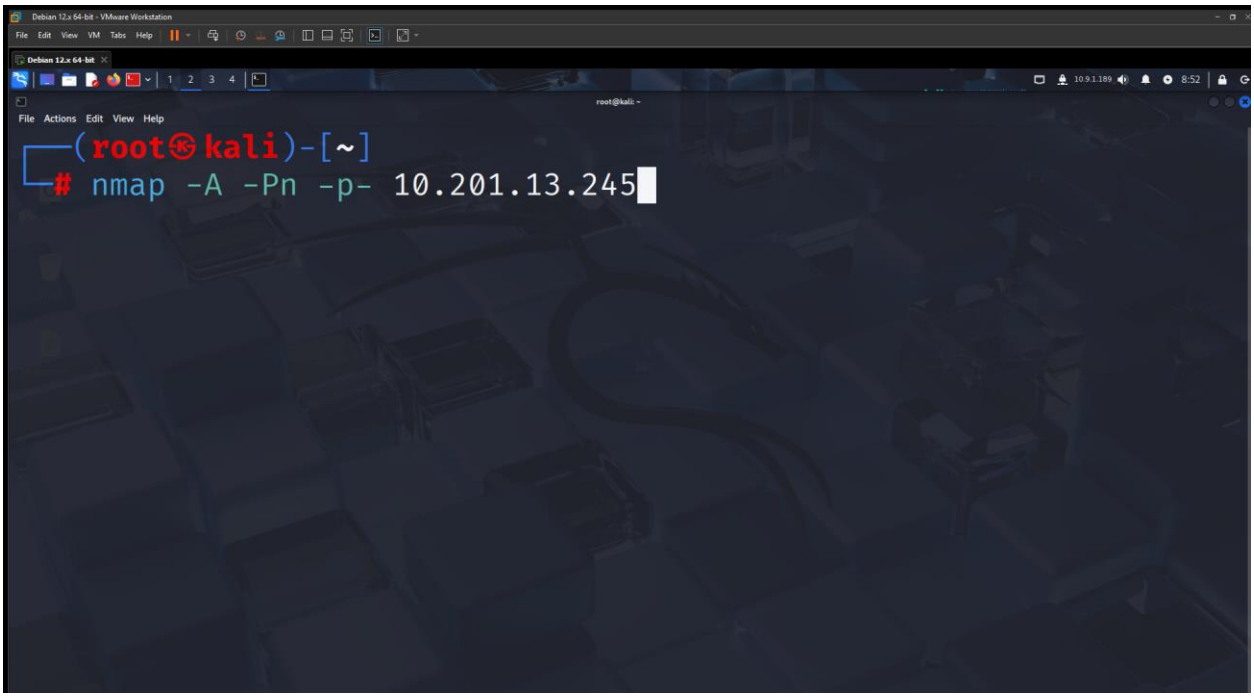


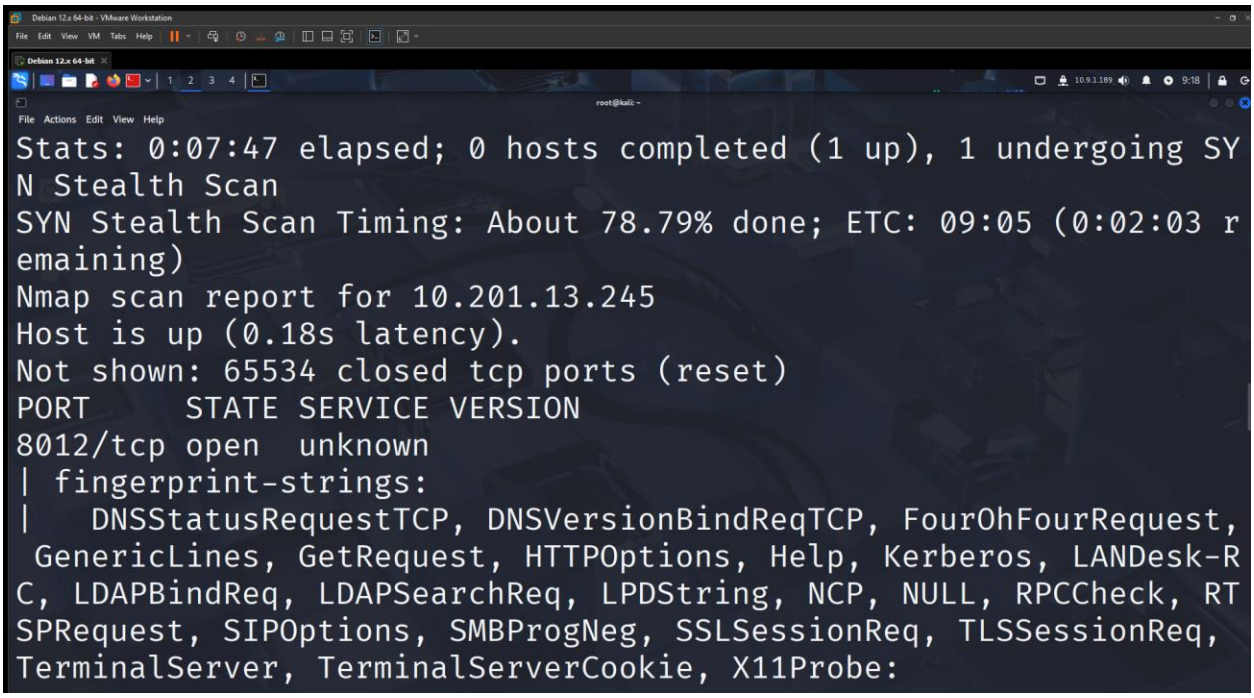
Telneti oxuyub sualları cavablandırırıq.



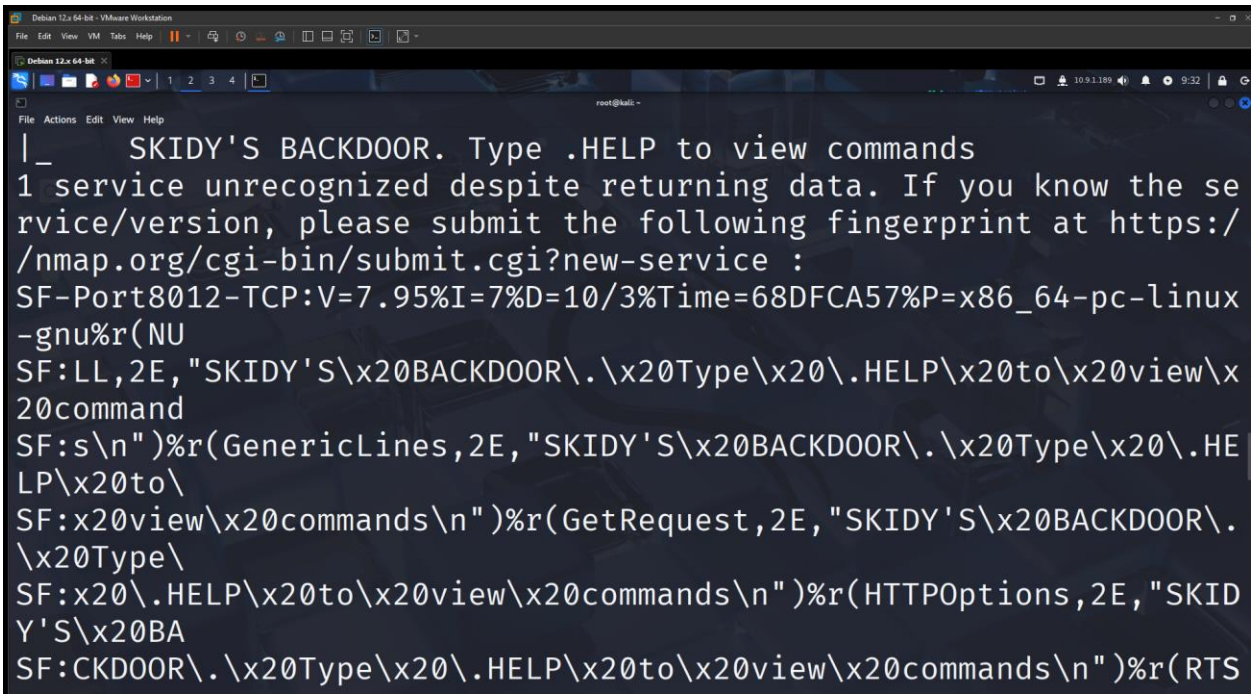


Enumerasiyaya keçirik.

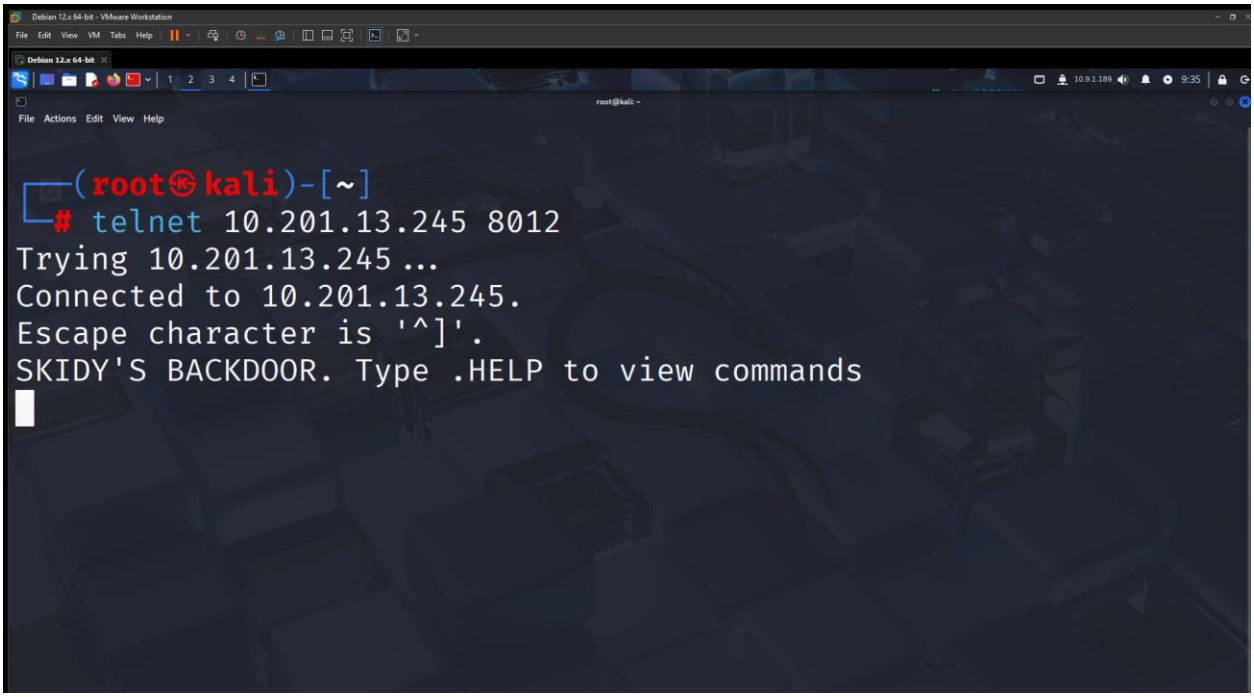




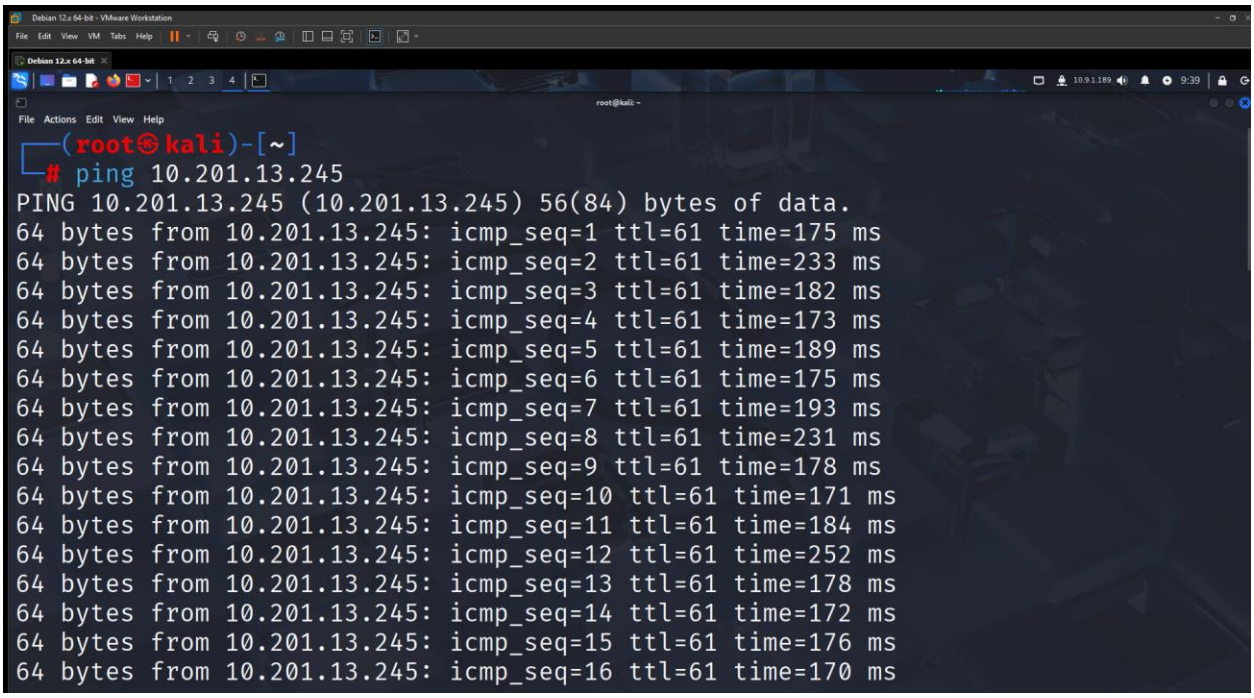
Klassik Nmap skanı ve aşıq portlarin tapılması və nömrələrinin öyrənilməsi

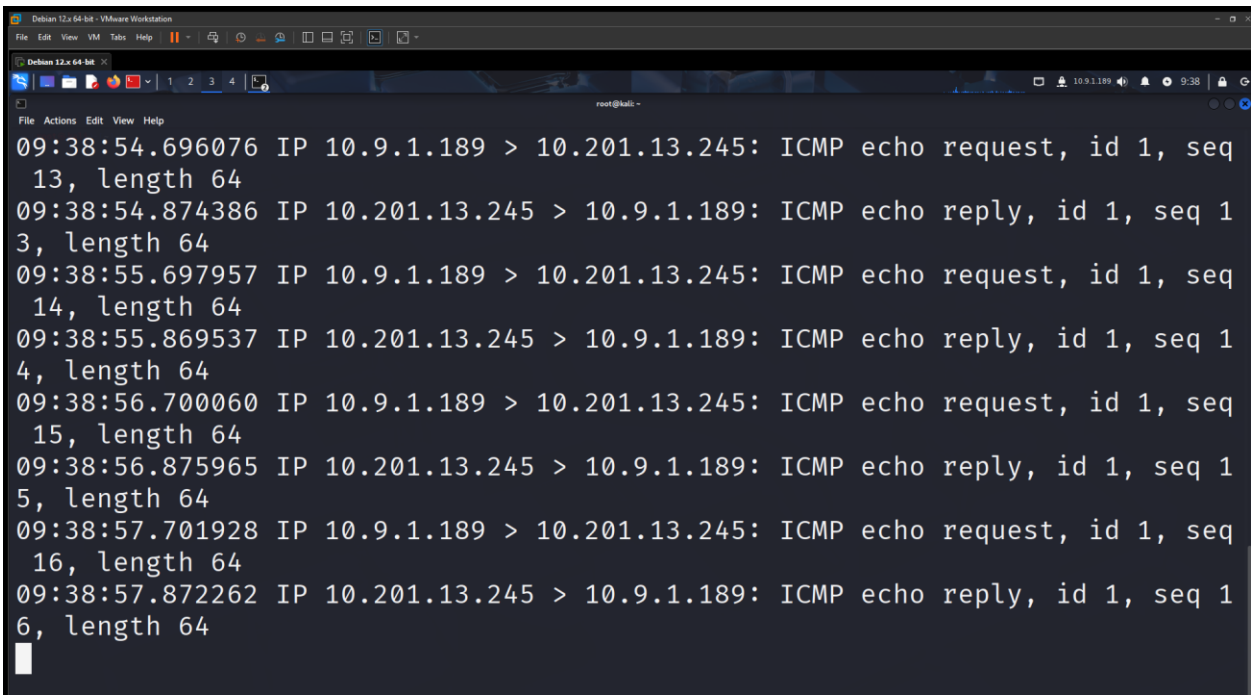


Suallarda portun nə üçün istifadə olunduğu və usernme soruşulub.

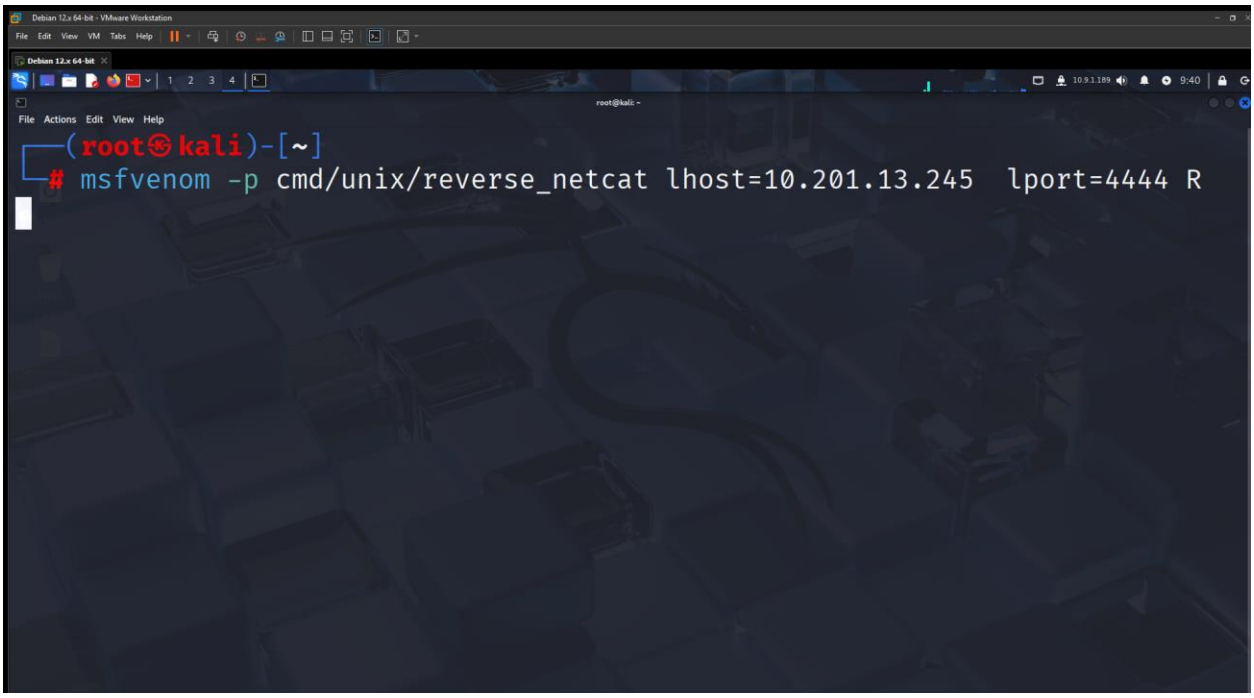


Telnetlə qoşuluruq.

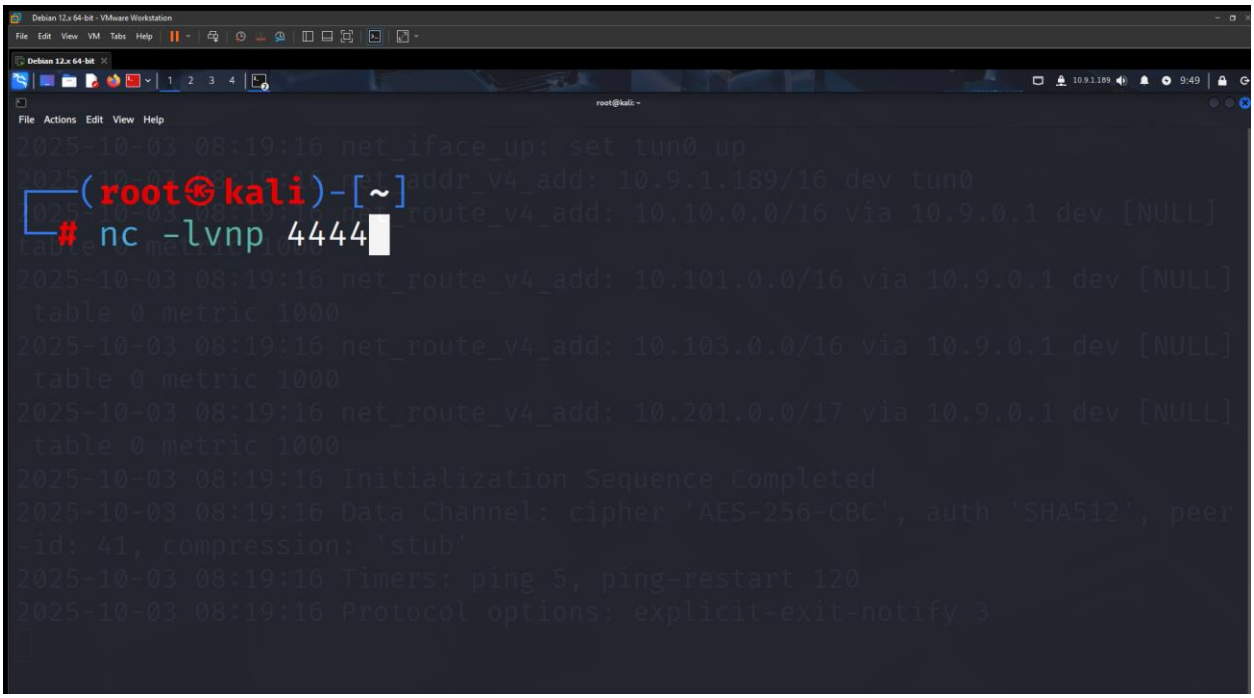




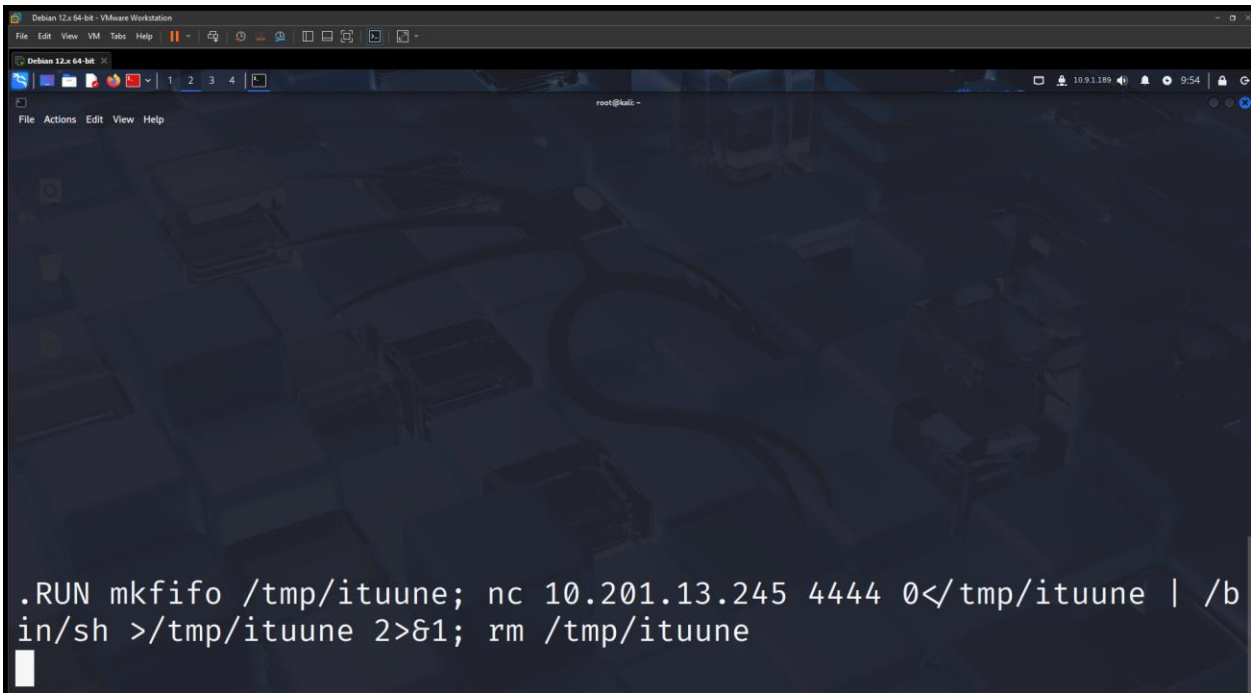
Burda tcpdump əmri yazıb daha sonra isə ping atmağımız lazım olduğu deyilir



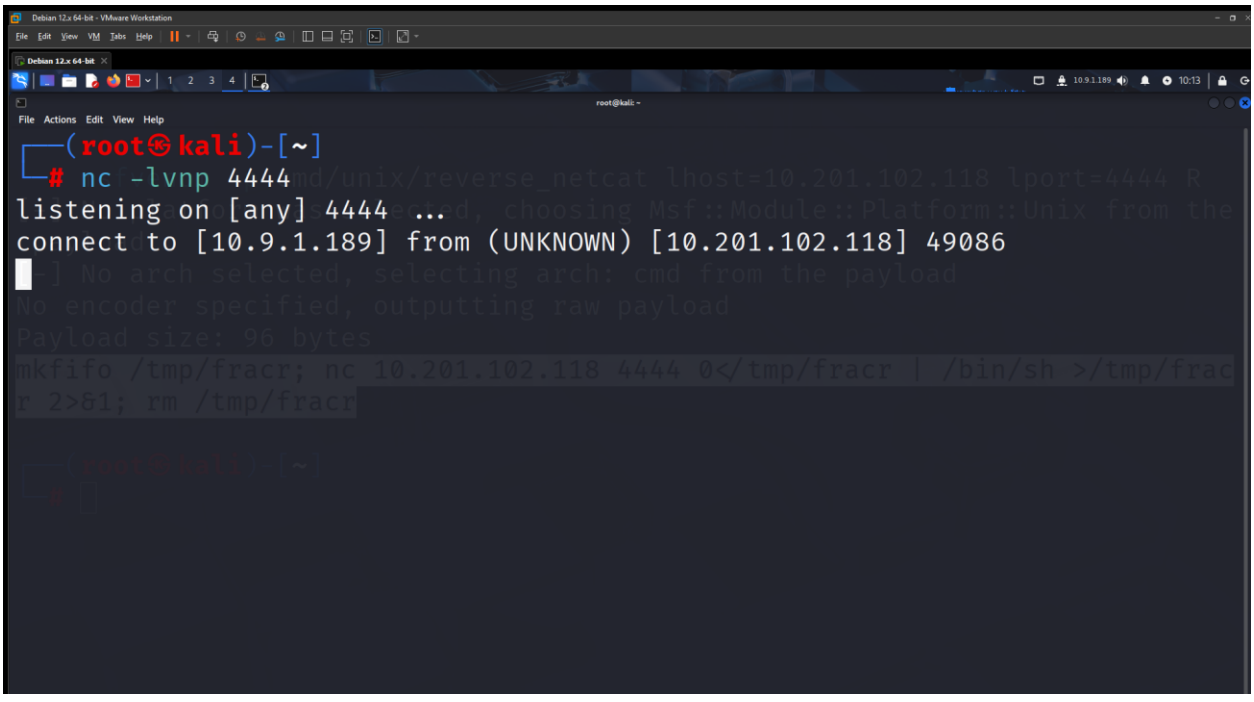
Burda Payload yaradırıq



Netcat açırıq



Payloadı işə salırıq

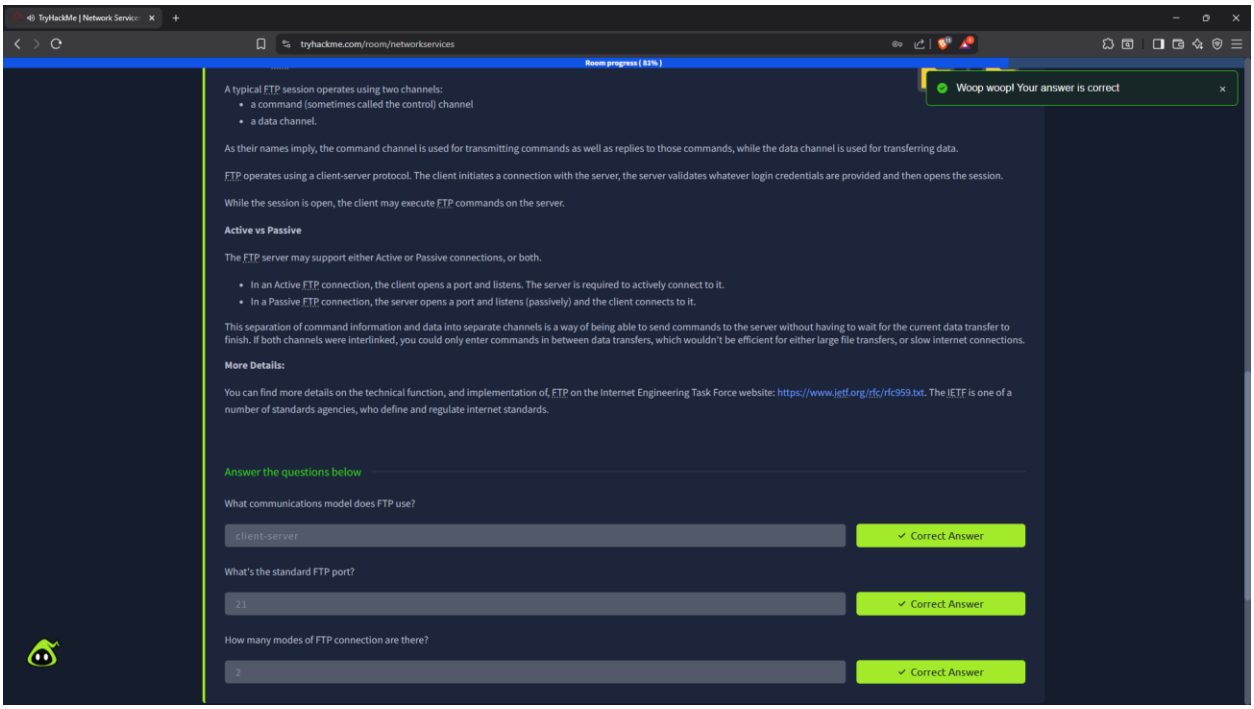


Aha deməli alındl.

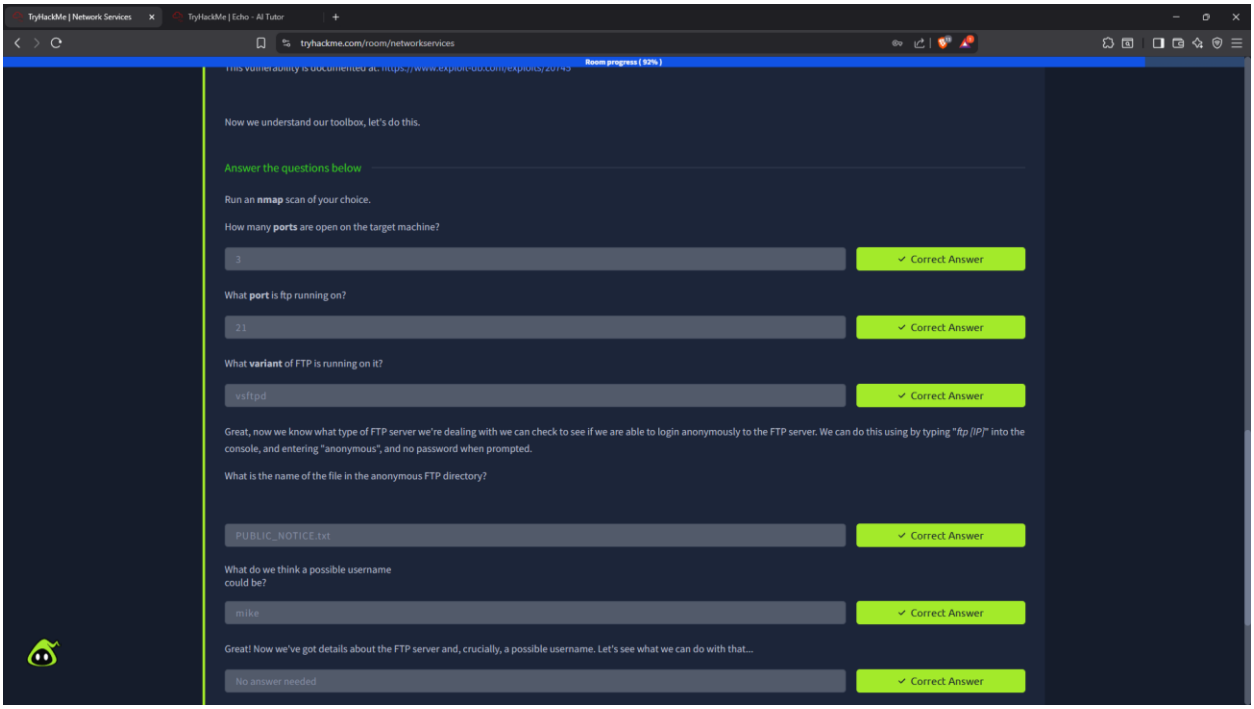


Son olaraq isə flagi oxuyuruq.

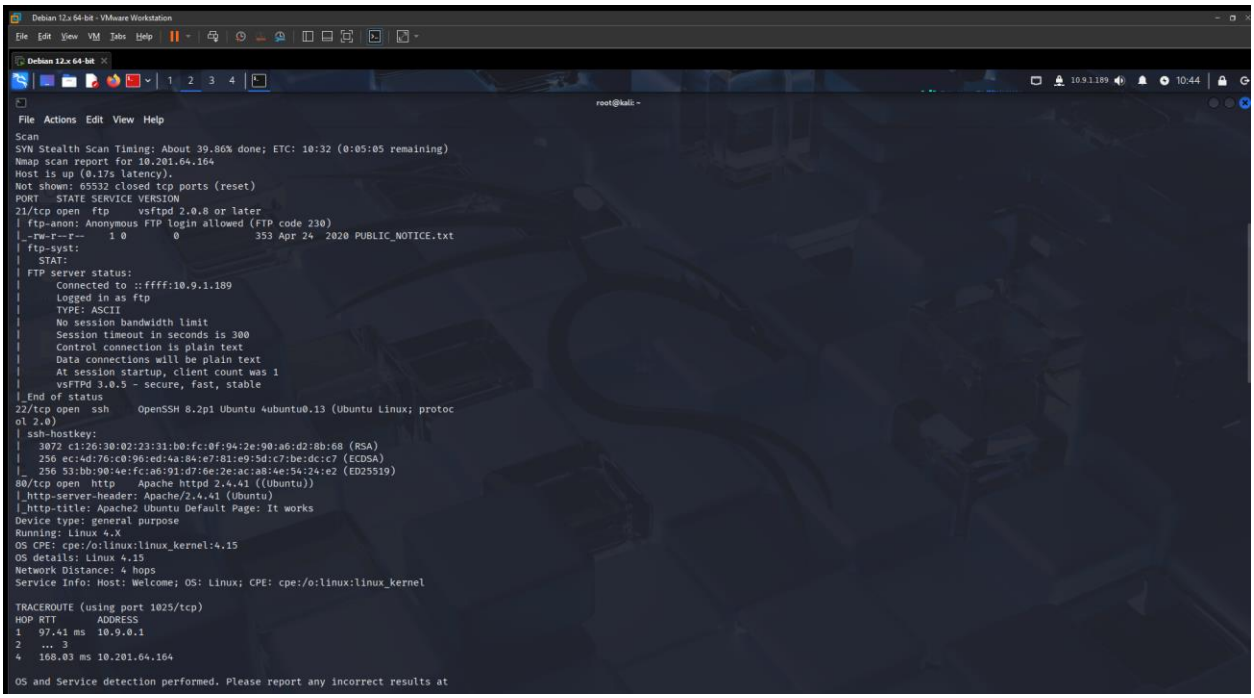
FTP



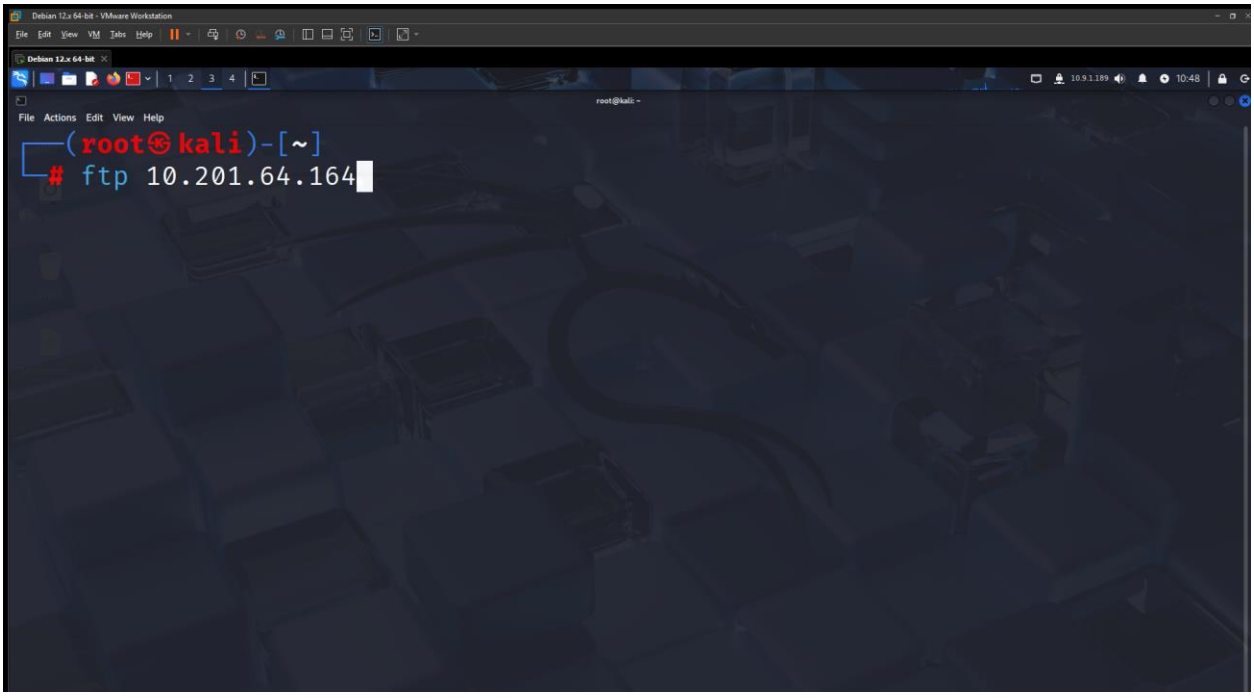
Ftp haqqında məlumatları oxuyub tapşırıqları yazırıq.



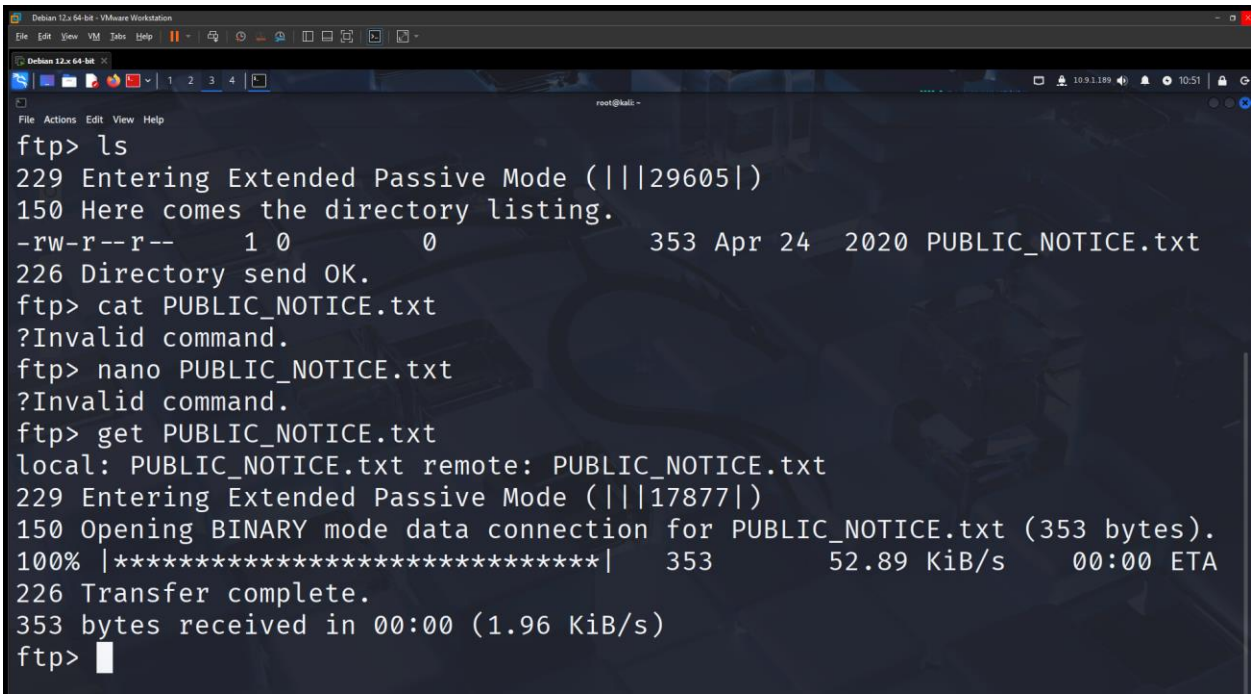
Izaha keçək.



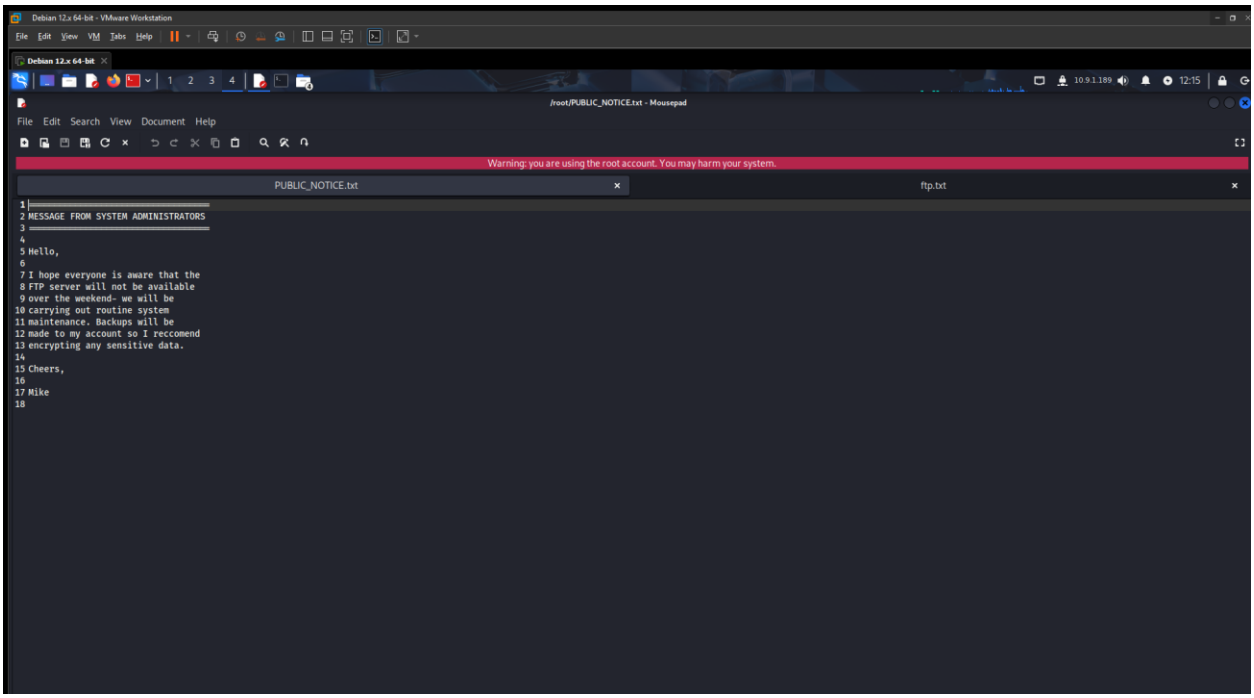
Nmap skanı



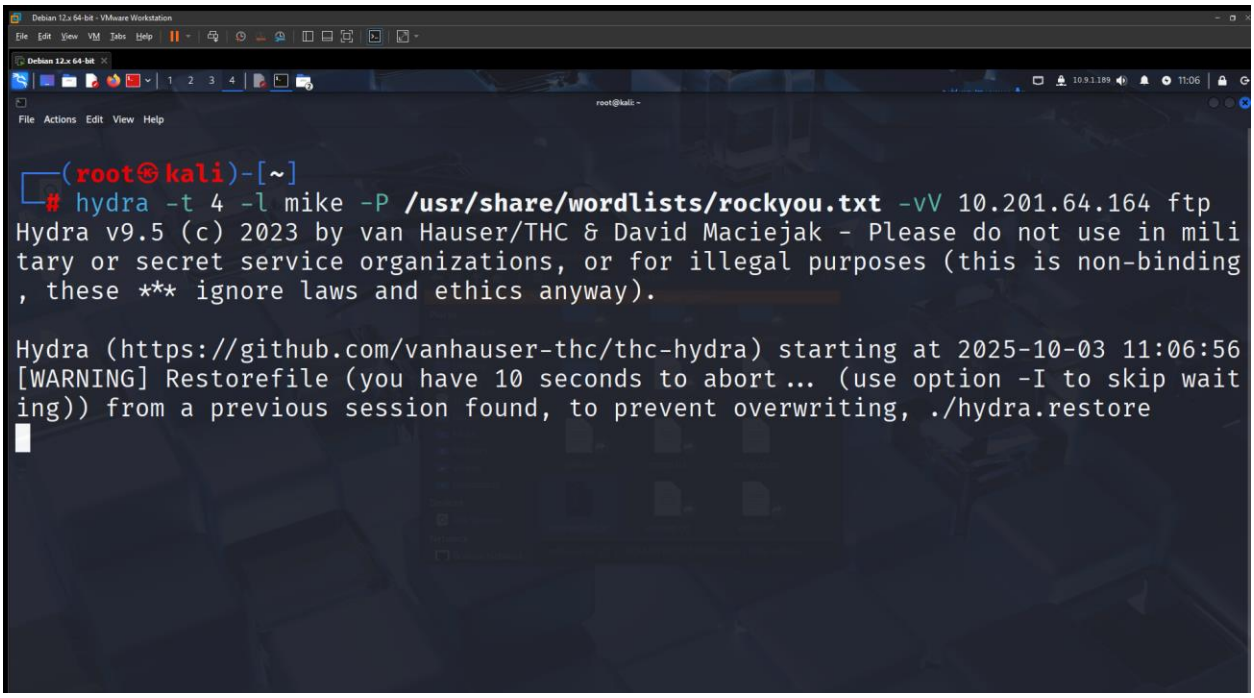
Ftp ilə qoşulmağa cəhd edirik.

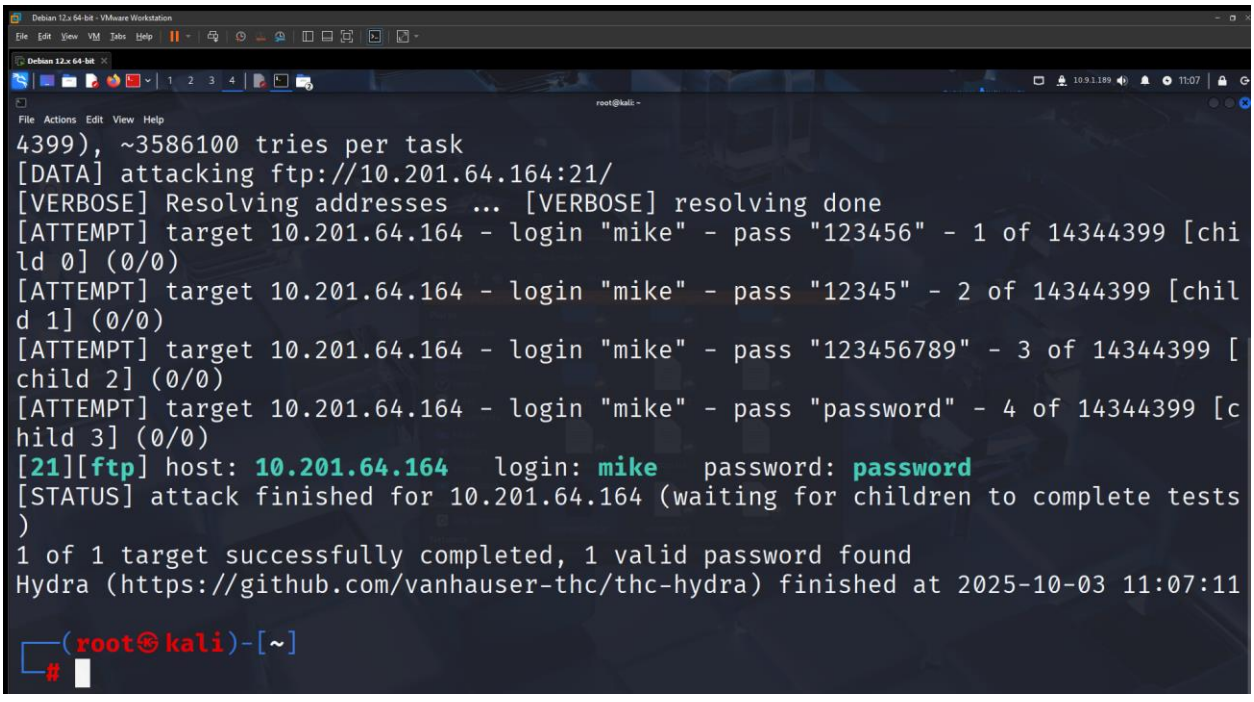


Qoşulduqdan sonra vacib görunən faylları pc yə köçürdürük.

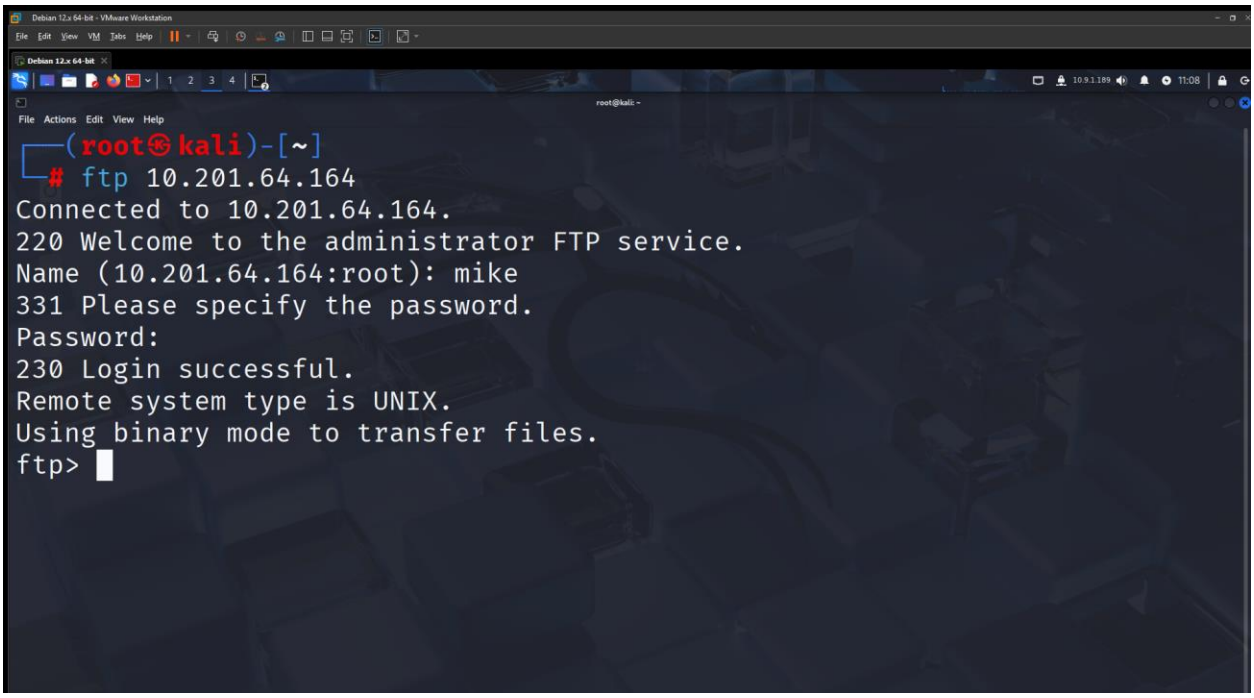


Username tapdıq Mike. İndi isə Hydra ilə parolun tapaq.

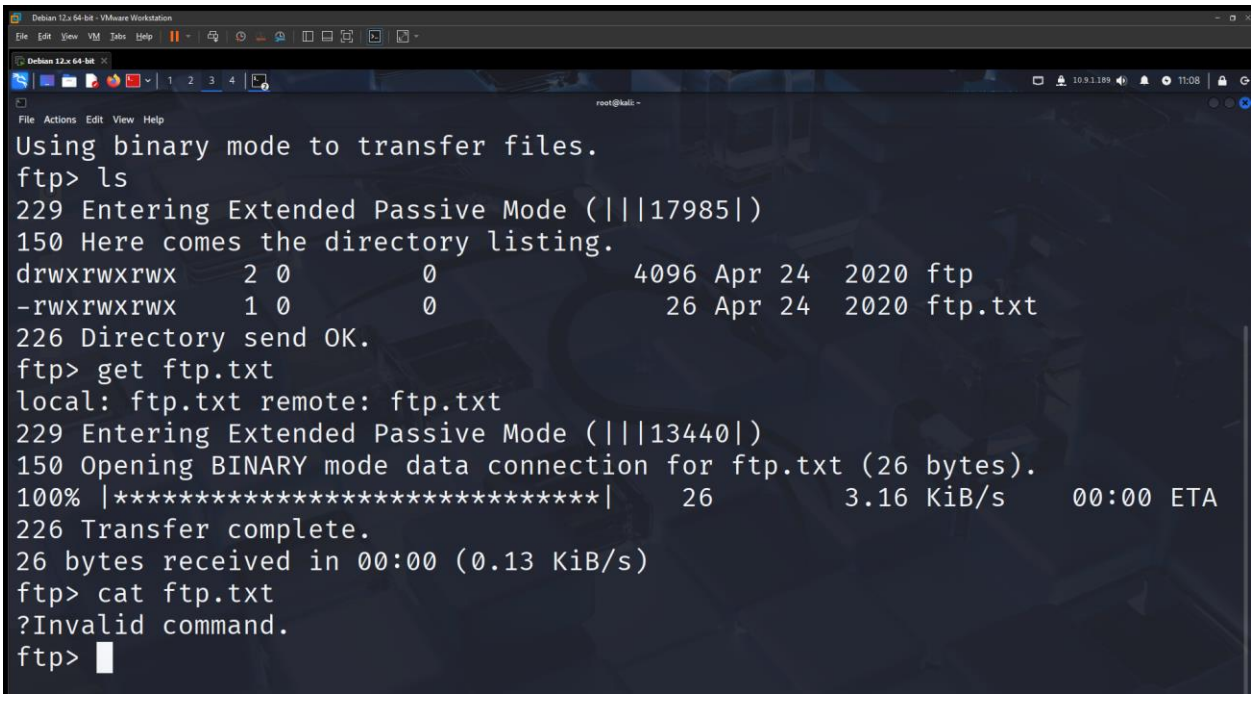




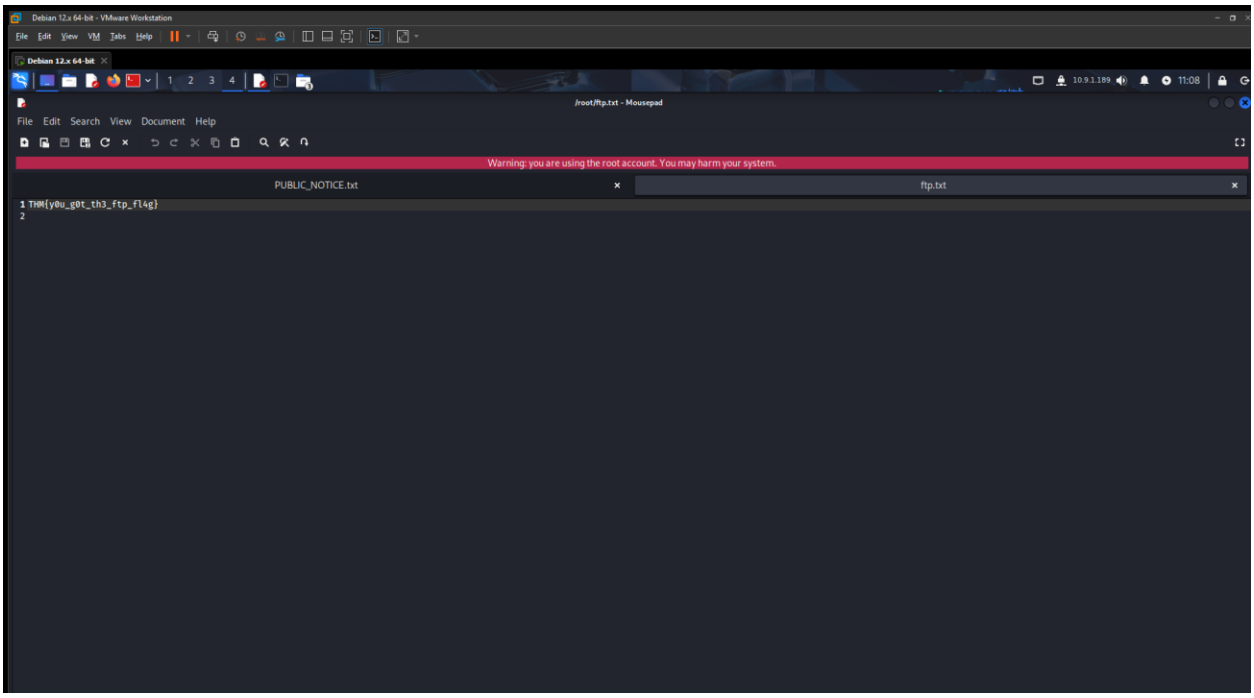
Parol Çox güclü imiş))



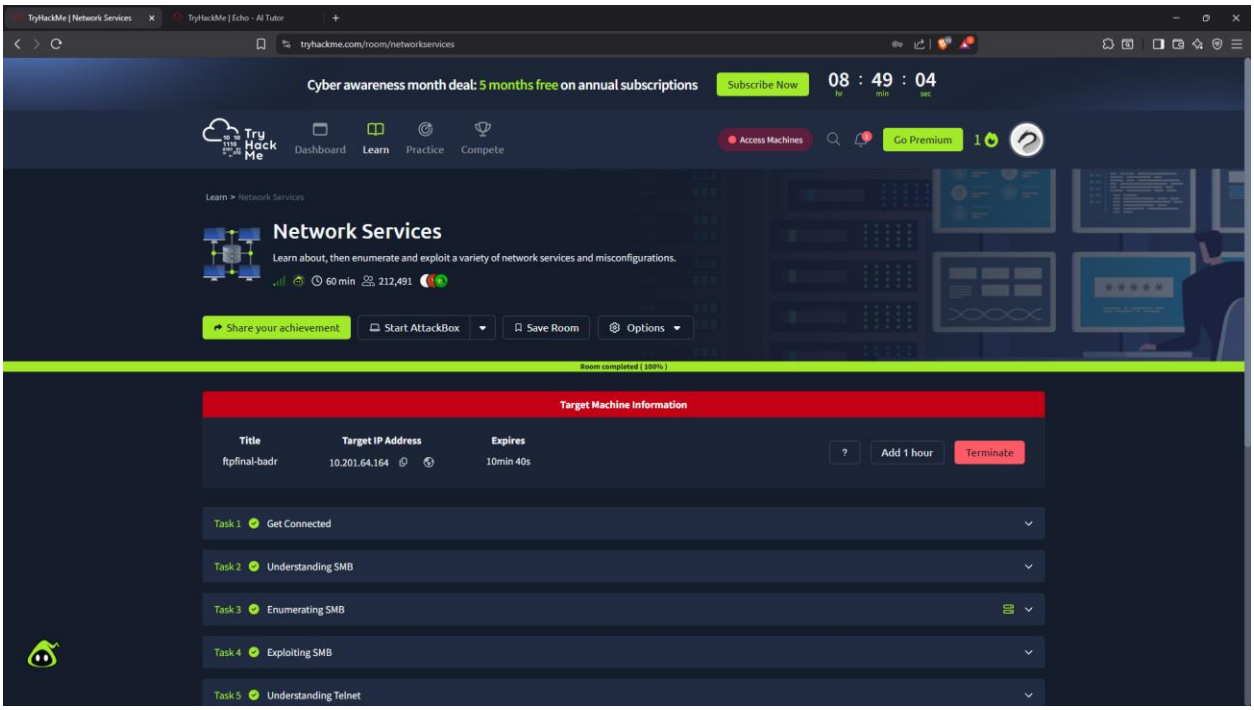
Mike userinə sızdıq.

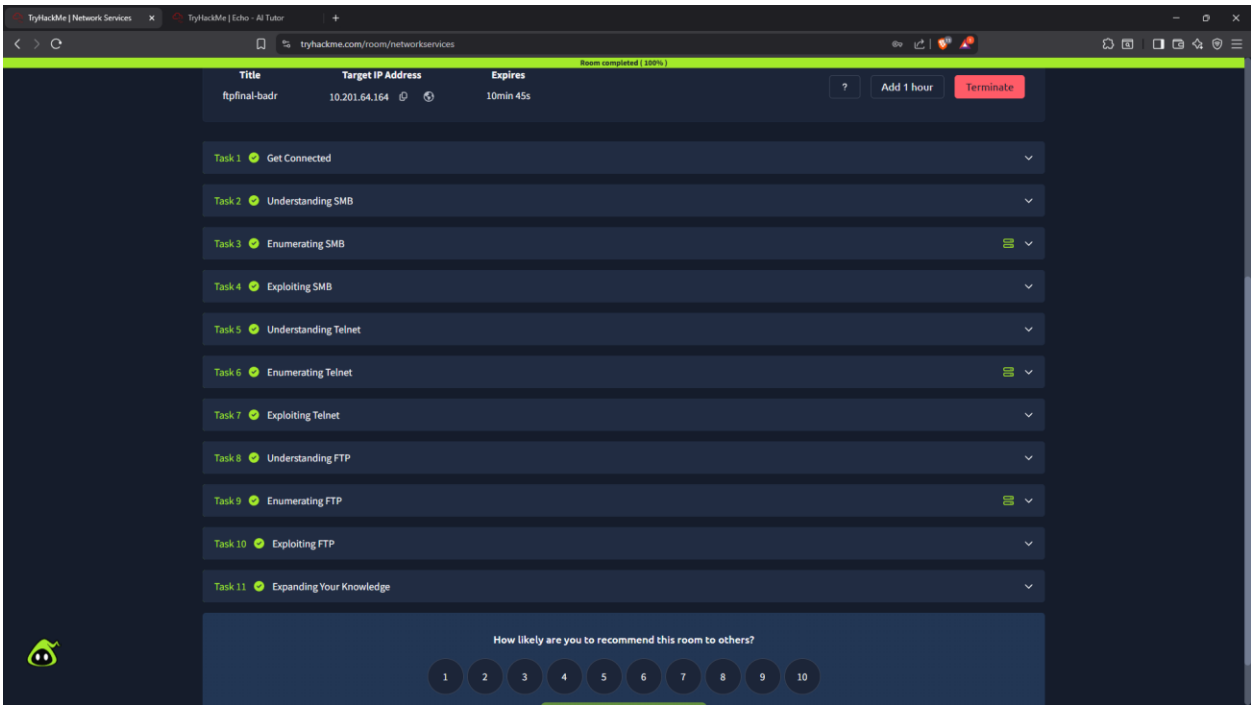


Flagı pc-yə köçürdük.



Flagi tapdıq.





Təşəkkürlər.